02. 네트워크

* 프로토콜 (Protocol) : 시스템 간에 통신하기 위한 규약 - 구문, 의미, 타이밍
* 구성요소
- 구문 : 송수신 데이터 포맷
- 의미 : 데이터의 각 항목이 가지는 의미
- 타이밍 : 데이터 송수신 동작 방식을 정의

* OSI 7 Layer : Application, Presentation, Session, Transport, Network, Data link, Phyical
- 국제 표준화 기구에서 제정한 개방형 시스템 간 상호연결 (OSI : Open System Interconnection) 모델
- 분산된 이기종 시스템 간의 네트워크 상호호환을 위해 필요한 표준 아키텍처를 정의함
- 분할 정복 -> 기능에 따라 계층적으로 표준화 (하나의 큰 프로토코롤 설계 X , 따로 따로)

* 노드 : 네트워크에 연결된 장치를 의미함. 네트워크에 연결된 컴퓨터를 포함하여 네트워크 프린터와 같은 주변기기, 라우터, 스위치, 허브와 같은 통신 장비를 포함함

* 종단 노드 : 통신의 양 끝단에 해당하는 노드로 최초 송신노드와 최종 수신 노드를 의미함

* 링크 : 노드 사이에 패킷 전달을 위한 물리적인 통신 경로

* 물리 계층 : 물리적 장치의 전기적, 전자적 연결에 대한 명세, 주소 정보 없음 (-> 목적지 인식 불가하여 모든 노드에 전달), bit, 허브(더미허브 -> 들어오는 신호를 모든 포트로 전달) , 리피터

* 물리 계층에서의 스니핑 : NIC 의 동작 모드를 무차별 모드 (Promiscuous Mode) 로 설정하면 자신이 목적지가 아닌 패킷도 모두 수신하므로 더미 허브 환경에서 스니핑 가능 (원래는 목적지 패킷제외 NIC 에서 걸러져서 폐기)
* 스니핑 도구 : Wireshark, Tcpdump

* 데이터 링크 계층 : 인접한 노드 간의 신뢰성 있는 프레임 전송을 담당하는 계층 (인접노드), MAC(프레임에대한주소) 설정, NIC 에 MAC 주소 설정, 프레임, 프로토콜(이더넷, 토큰링, FDDI, X.25, Frame Relay)

* IEEE 802 표준 -> LAN 상의 데이터 링크 계층을 LLC 와 MAC 으로 구분

* 데이터링크 -> 신뢰성 있는 전송, 흐름제어(정지대기 Stop and Wait -> 확인 응답 /슬라이딩 윈도우 Sliding Window-> 수신범위 내에서 확인응답없이 전송), 오류제어 (Backward Error Correction -> 송신측에서 데이터 전송시 오류를 검출할 수 있는 부가 정보를 함께 전송(Automatic Repeat Request) -> 재전송 요청 , Forward Error Correction -> 재전송 불필요, 송신측에서 데이터 송신시 오류의 검출 및 수정까지 가능한 부가정보를 담아서 전송) , 회선 제어(점대점, 다중점 -> 회선 구성 방식, 단방향, 반이중, 전이중 -> 전송 방식)

* 데이터 링크 - 스위치 : 스위치 장비는 내부적으로 MAC Address Table을 가지고 있음 -> 목적지로만 패킷 전송 가능 -> 스니핑 불가능 -> 스니핑 하려면 스위치 재밍, ARP 스푸핑, ARP 리다이렉트, ICMP 리다이렉트, 스위치의 SPAN/Monitoring Port 사용

* 데이터 링크 - 브릿지 : 물리적으로 떨어진 동일한 LAN 을 연결해주는 장비

* 스위치 환경에서 스니핑 공격 기법 - 스위칭 재밍 : 스위치 MAC address Table 의 버퍼를 오버플로우 시켜서 스위치가 허브처럼 동작하게 강제적으로 만드는 기법 , 스위치는 FailSafe/Open 정책을 따르므로 장애 ㅏㄱ 발생하면 더미 허브처럼 동작함 (연결된 모든 장치에 패킷을 전송) -> MAC address Table 을 오버플로우 시키기 위해 Source Mac 주소를 계속 변경하면서 패킷을 지속적으로 전송함
* Fail Safe : 장애 발생시 모든 기능을 허용 (가용성을 중시하는 장비에 사용)

* Fail Secure : 장애 발생시 모든 기능을 차단 (보안성을 중시하는 정책)

* ARP 스푸핑 : 공격자가 특정 호스트의 MAC 주소를 자신의 MAC 주소로 위조한 ARP Reply 패킷을 만들어 희생자에게 지속적으로 전송하면 희생자의 ARP Cache Table 에 특정 호스트의 MAC 정보가 공격자의 MAC 정보로 변경 된다. 이를 통해서 희생자로부터 특정 호스트로 나가는 패킷을 공격자로 향하도록 하여 스니핑 하는 기법이다. -> IP Forward 기능 활성화 필요 -> IP Forward : 일반적으로는 자신이 목적지가 아니면 패킷을 모두 폐기하지만 라우터처럼 동작하여 목적지 주소로 전송해줌

* ARP 리다이렉트 : ARP 스푸핑의 일종, 공격자가 자신이 라우터/게이트웨이인 것 처럼 MAC 주소를 위조하여 ARP Reply 패킷을 대상 네트워크에 지속적으로 브로드캐스트하면 해당 로컬 네트워크의 모든 호스트의 ARP Cache Table 에 라우터/게이트웨이의 MAC정보가 공격자의 MAC 정보로 변경 됨. 이를 통해 호스트에서 라우터로 나가는 패킷을 공격자가 스니핑 하는 기법

=> ARP 스푸핑 / ARP 리다이렉트 모두 희생자의 MAC Cache Address 를 변경하지만 ARP 스푸핑은 희생자와 특정 호스트의사이에서 특정 호스트의 MAC 주소를 스푸핑한다면 리다이렉트는 게이트웨이 주소를 스푸핑한다

* ICMP 리다이렉트 공격 : ICMP Redirection 메세지는 호스트-리우터 또는 라우터 간에 라우팅 경로를 재설정하기 위해 사용하는 메시지이다. 공격자가 이를 악용하여 특정 IP 또는 IP 대역으로 나가는 패킷의 라우팅 경로를 자신의 주소로 위조한 ICMP Redirect 메세지를 생성하여 희생자에게 전송함으로써 희생자의 라우팅테이블을 변조하여 패킷을 스니핑하는 공격 기법이다. -> IP Forward 기능 사용

* 스위치의 SPAN/Port Mirroring : 스위치를 통과하는 모든 트래픽을 볼 수 있는 기능으로 특정 포트에 분석 장비를 접속하고 다른 포트의 트래픽을 분석 장비로 자동 복사해주는 기술 -> SPAN : 특정 포트의 트래픽을 분석 장비로 자동 복사해주는 기술

* 네트워크 계층 : End To End Delivery (종단노드, Host to Host Delivery) 간의 라우팅을 담당함
-> 라우팅: 라우팅 알고리즘에 의해 목적지로 전송하기 위한 최적의 경로를 설정하고 패킷을 교환하는 기능을 제공 (노드에 대한 논리적인 주소가 필요함 -> IP 주소가 논리적인 주소 역할) , 패킷, 프로토콜 (IP, IPX)

* 라우터 : 라우팅을 담당하는 장비, 데이터 링크 계층의 브로드캐스트와 멀티캐스트를 포워딩 하지 않음 , 서로 다른 VLAN 간에 통신을 가능하게 하고 기본적인 보안 기능과 Qos 관련 기능을 지원

* 네트워크 계층 : End To End Reliable Delivery (End 노드간의 신뢰성 있는 데이터 전송을 담당 -> 프로세스간 신뢰성 있는 데이트 전송 담당 -> Port Address 가 주소역할), 세그먼트, 프로토콜 (TCP, UDP, SCTP, Novel Netware SPX), 흐름제어(상호간에 수신할 수 있을만큼만 전달, 데이터계층에서는 인접 노드간에만 흐름제어를 하지만 전송 계층에서는 양 종단노드간에 흐름제어를 수행함) , 오류제어(종단노드간 전송 중 오류 발생시 교정), 혼잡제어(네트워크 혼잡도 계산), L4 switch
* 신뢰성 있는 데이터 전송의 보장을 위한 기능 -> 분할/재조합, 연결제어(연결지향 -> TCP /비연결지향 -> UDP)

* 세션계층 : Application간 논리적인 연결인 세션의 생성, 관리 및 종료를 담당함
* 표현계층 : 데이터 표현 방식과 변환을 담당, 인코딩/디코딩, 압축/압축해제, 암호화/복호화 데이터
* 응용 계층 : 사용자가 네트워크에 접근할 수 있는 인터페이스를 담당, 네트워크 서버/클라이언트 프로그램, 데이터

* OSI 모델 데이터 교환 방식 : 상위계층데이터가 하위로 이동할 경우 캡슐화 (전송, 상위 -> 하위 : 필요한 기능을 헤더에 추가) , 하위계층데이터가 상위로 이동할 경우 역캡슐화 (수신, 하위 -> 상위 : 헤더정보 확인후 제거)

* 다중화: 하나의 기능을 여러 영역에서 동시에 사용함 , 상위 계층의 여러 프로토콜이 하위 계층의 하나의 프로토콜을 이용하여 데이터를 전달하는 방식. 헤더에 프로토콜 식별자 정보 추가
* 역다중화 : 공유하는 기능(매체)로부터 개별 영역으로 분할, 하위 계층의 프로토콜이 여러 상위 계층 프로토콜 중 하나를 식별하여 데이터를 전달하는 방식. 상위 프로토콜을 구별하기 위한 프로토콜 식별자 정보를 이용 -> 이 때 프로토콜 헤더에 있는 정보는 다중화시 사용됨

* tcp/ip 프로토콜 - application layer(응용계층) : 네트워크 서버/클라이언트 프로그램 담당, 사용자와의 인터페이스 담당
-> 주요 프로토콜 : http(80/tcp), ftp(20~데이터/21~제어/tcp), ssh(22/tcp), sftp(22/tcp), telnet(23/tcp), smtp(25/tcp/메일전송용), pop3(110/tcp/메일수신용), imap(143/tcp/메일수신용~복사), dns(53/tcp,udp), dhcp(67,68/udp), tftp(69/udp), snmp(161/udp)

* tcp/id 프로토콜 - transport layer(전송계층) : 프로세스간 신뢰성 있는 전송을 담당 -> 오류, 누락 및 흐름제어, 혼잡제어 수행 / 프로세스 식별을 위해 16bit 의 논리주소 사용
-> 주요 프로토콜 : tcp(스트림기반 신뢰성 있는 전송), udp(비신뢰적인 비연결형 프로토콜, 데이터 그램 기반 전송), sctp(tcp와udp의 조합형)

* tcp/id 프로토콜 - 인터넷 계층 : 호스트간 라우팅을 담당하는 계층, 호스트 식별을 위한 논리 주소로 ipv4(32bit), ipv6(128bit) 주소를 사용함
-> 주요 프로토콜 : IP(비신뢰적인 비연결형 데이터그램 프로토콜), ICMP(에러 및 상태진단 메시지 프로토콜), IGMP(멀티캐스트용), ARP(IP->MAC), RARP(MAC -> IP)

* tcp/id 프로토콜 - 네트워크 인터페이스 계층 : node to node delivery, 인접한 노드간에 신뢰성 있는 데이터 전송을 담당하는 계층. node 식별을 위해 mac 주소를 사용함 (mac 주소구성 : 상위24 비트는 제조사 식별코드, 하위 24비트는 제조사가 할당한 일련번호에 해당)
-> 주요 프로토콜 : LAN(Ehternet, TokenRing, FDDI), WAN(X.25, Frame Relay, PPP, SLIP)

* ARP/RARP 프로토콜 : 논리적인 주소와 물리적인 주소 사이의 변환을 담당함
* ARP 동작 방식 : 대상 서버(노드)의 Ip 를 broadcast request -> 해당 노드가 자신의 mac 정보를 담아서 unicast reply
-> 브로드 캐스트 : 로컬 네트워크 내의 모든 호스트에 동시에 패킷을 전송하는 통신 방식 (2계층 이더넷 프레임의 목적지 mac 주소는 48bit 가 모두 1로 설정된 FF:FF:FF:FF:FF:FFF 주소를 사용
-> 유니캐스트 : 1:1 로 패킷을 전송하는 통신 방식
=> ARP 통신시 ARP Cache 에 일정시간 통신한 정보를 보관함

* RARP 동작 방식 : 자신의 mac 주소를 담아서 자신의 정보를 요청 하는 request 를 rarp server 에 broadcast
-> rarp server 에서 요청자의 ip reply 를 unicast

* arp cache table : 동적(dynamic)/정적(static)
-> arp 요청을 통해 알아낸 mac 정보는 통상 1~2분정도 메모리에 저장됨. apr -a 명령을 통해 ARP cache table 을 찾아보면 타입이 dynamic 또는 static 으로 지정된 것을 볼 수 있음. dynamic 은 일정시간동안 유지 되지만 static 은 관리자가 삭제하거나 시스템이 종료되기 전까지 지속적으로 유지 됨
-> apr -a : 캐시내용 확인 / apr - d : cache 테이블 삭제 (리눅스의 경우 뒤에 ip 까지 명시 필요), apr -s ip mac주소 를 사용하여 정적으로 설정 가능

* arp spoofing 공격(apr cache posioning)
- 2 계층에서 동작함. 2계층 주소는 서로 다른 네트워크로 라우팅 되지 않기 때문에 공격 대상도 동일 네트워크 대역에 있어야 함
- 희생자 간의 송수신 패킷을 공격자가 스니핑함 (A 가 B 에게 보낸 패킷이 사실은 B 로 위장한 공격자에게 전송되는 방식. 상호간의 패킷을 모두 스니핑하고 싶다면 A 뿐만 아니라 B 에게도 변조된 ARP reply 를 전송하여 ARP cache table 내용을 바꿔줘야 함
- IP forward 기능을 활성화 시킴
-> 대응방안 : arp 요청 및 응답 과정에서 별도의 인증과정이 없는 arp 프로토콜 자체의 취약점을 이용한 공격이기 때문에 완벽한 방어는 없다. 일반적인 대응 방법은 arp 캐시를 정적으로 설정하여 arp 응답을 수신해도 캐시정보를 갱신하지 않도록 해야 한다. 또는 arp 트래픽을 실시간으로 모니터링하는 프로그램등을 이용하여 IP 와 mac 주소의 매핑을 감시하고 변경 발생시 확인하도록 한다

* garp (Gratuitous ARP) : Gratuitous는 불필요한 이라는 의미로 Sender IP 와 Target IP 가 동일한 ARP 요청을 GARP 라고 한다.

-> 장비가 arp 요청 브로드캐스트를 통해서 다른 장비에게 네트워크에 있는 자신의 존재를 알리는 목적으로 사용 되는 패킷이다. 자신의 mac 정보를 동일 네트워크 상의 다른 장비들에 알려 arp cache를 갱신하도록 하는 목적을 가진다. IP 충돌 감지 목적도 있다. (호스트의 IP를 변경하거나 재부팅시에 GARP 패킷을 생성한다)

* Man In The Middle (중간자 공격) : 네트워크 통신을 조작하여 통신 내용을 도청 및 조작하는 기법 . 두 사람은 각각 상대방에게 정상적으로 연결되었다고 생각하지만 실제로는 두 사람은 중간자와 연결되어 있으며 중간자가 한쪽에서 전달된 정보를 도청 및 조작한 후 다른 쪽으로 전달한다.

* IP 프로토콜 : 비연결형 프로토콜로 연결 상태를 유지하지 않기 때문에 패킷 전송 순서를 보장하지 않는다. 비 신뢰적 프로토콜로 신뢰성 있는 통신을 보장하지 않는다. 라우팅을 담당하는 인터넷 계층의 대표 프로토콜이다.

* IP 프토토콜 구조
- 헤더 : 기본 20byte + 옵션 헤더 40byte (따라서 아이피 헤더는 20 ~ 60 byte 를 가짐)
- identification(16bits) : 단편화/재조합 관련 필드. 단편화 전 원본 IP 데이터그램을 식별하기 위한 ID 를 의미한다.
- Flags (3bits) : 단편화/재조합 관련 필드 -> 첫번째 필드는 사용안함, 두번째 비트(don't fragment bit)에 1을 설정하면 패킷을 단편화 하지말라는 뜻, 세번째 비트(more fragments bit)는 1을 설정하면 재조합할 단편이 남아 있다는 의미이고 0 설정시 단편이 더 이상 없다는 의미이다
- fragmentation offset(13bits) : 단편화/재조합 관련 필드 -> IP특성상 원본 IP 데이터그램의 단편들이 순서대로 전송되는 것이 아니므로 이를 순서대로 조합하기 위한 현재 단편의 상대 위치를 저장한 필드로 8 bytes 단위로 표현함
- Time to live(8 bits) : IP 패킷의 생존시간을 지정하는 필드 -> 라우터/L3 스위치 통과 횟수(hop count)로 의미가 바뀜 . 스위치에 도착할 때마다 TTL 이 하나씩 감소 됨 . 0 이 되면 패킷을 폐기, TTL 을 설정하여 라우팅 중 발생할 수 있는 무한 루핑을 방지할 수 있음. Linux 는 64, Window 는 128, Unix 는 255 가 초기 값 (OS 별로 초기값이 달라서 OS 핑거 프린트 역할도 함)

* IP 단편화 : MTU(물리적인 네트워크 프로토콜 프레임의 데이터부의 최대 크기를 의미), 단편화를 사용해 패킷 크기 조절이 가능함. (이더넷의 MTU 는 1500 바이트), 단편화는 최초 출발지 뿐만아니라 라우터/L3스위치 중계 구간의

MTU에 따라 추가적으로 발생하지만 단편화된 패킷은 통신 효율을 위해 중계 구간의 MTU가 달라진다고 해도 재조합 되지 않으며 최종 목적지에서만 재조합 됨. (단편의 손실이 발생할 경우 ICMP 메시지를 최초 출발지로 전송하고 재조합에 실패한 모든 단편을 폐기함 -> ICMP Time exceeded, Fragment reassembly time exceeded)

* tcpdump 의 IP 단편화 관련 출력 형식 : frag "단편ID":"단편의크기(IP헤더제외)"@"오프셋"+)
-> + 있음 : 추가 단편 있음 = more fragments bit : 1
-> + 없음 : 마지막 단편 = more fragments bit : 0

* IP 라우팅 : 목적지 주소가 자신과 동일한 네트워크에 있으면 직접 전송 -> 직접 전송이 불가능 하다면 1차 경유지 주소(게이트웨이주소)를 라우팅 테이블을 참조하여 찾음 (라우팅 테이블은 임의의 목적지로 가기 위한 경로 정보를 저장하고 있는 자료 구조로 netstat -rn 명령을 통해 호스트의 라우팅 테이블 정보를 확인할 수 있음) -> 목적지 주소와 자신의 주소가 동일한 경우 목적지가 자신이므로 상위 계층으로 데이터를 전달함

* 라우팅 테이블 검색 방식 및 우선 순위 : ip 패킷의 목적지 ip 와 라우팅 테이블의 netmask / genmask 를 bit and 연산 수행 후 라우팅 테이블의 destination 필드와 비교, 일치하는 경로를 선택하여 패킷을 전송한다 (패킷의 목적지 IP 와 netmask/genmask 간에 bit and 연산을 한다는 의미는 목적지 IP 에서 네트워크 ID 부분만을 추출하기 위한과정임, 검색 우선순위는 목적지 호스트 주소와 일치하는 경로를 찾고 일치하는 경로가 없으면 호스트 주소가 아닌 네트워크 주소와 일치하는 경로를 찾는다. 둘 다 없으면 default gateway(0.0.0.0) 으로 보낸다.

* IP spoofing : IP 를 속이고 통신하는 공격으로 1995년 캐빈미트닉이 이를 이용하여 실제 해킹을 시도함으로써 널리 알려진 공격 방식이다 (캐빈 미트닉 -> IP Spoofing, Session Hijacking) , 시스템 간의 트러스트 관계를 이용하여 트러스트 관계가 맺어진 서버와 클라이언트를 확인한 후 신뢰 관계가 있는 클라이언트를 연결 불가능한 상태로 만들고 공격자가 클라이언트의 IP로 위조하여서버에 접속하는공격 방식 (트러스트 관계는 아이디 패스워드 기반의 로그인이 아닌 IP 주소로 인증하고 로그인 없이 접속할 수 있도록 해주는 방식 -> 보안상 취약하여 사용 비권장, 유닉스와 리눅스 시스템에서 /etc/hosts.equiv (시스템 전체에 적용) , $HOME/.rhost (사용자별로 설정) 파일에 설정여부를 확인할 수있음, r 계열 서비스는 인증없이 신뢰 관계에 있는 시스템들의 원격접속을 허용해주는 서비스임 . 사용안하는게 제일 좋지만 꼭 사용 해야 한다면 mac 주소를 static 으로 설정하여 아이디만 위조한다고해서 접근할 수 없게 막아 줘야함, 파일 소유자는 root,파일권한은 600 권장, 파일 설정에서 + 제거)

* IPv6 : IPv4 주소가 고갈되는 문제를 해결하기 위해 새로운 128비트 체계로 2^128개의 주소를 갖는 인터넷 프로토콜 주소를 의미함 (16비트 단위로 16진수로 변환되어 콜론으로 표기), 앞의 64비트는 네트워크주소이고 뒤의 64비트는 네트워크에 연결된 통신장비 등에 할당되는 인터페이스 주소를 의미함

-> 확대된 주소공간, 단순해진 헤더 포멧, 간편해진 주소 설정기능(내장된 주소 자동설정 기능으로 플러그 앤 플레이 설치 가능, IPsec 기능을 기본 사항으로 제공하여 강화된 보안성, 헤더에서 이동성을 지원하여 개선된 모바일 IP

* IPv6 - IPv4 전환기술 : 듀얼스택(IPv4, IPv6 동시 설정 하여 통신 상대에 따라 선택적으로 사용할 수 있도록 제공), 터널링(Ipv4 네트워크를 경유하여 IPv6 네트워트간 통신을 위한 방식으로 IPv4 네트워크를 통과하는 가상의 경로를 만들어 통신하는 방식 (IPv6 를 캡슐화 하여 IPv4 네트워크를 통과하게 변환) , 주소변환 (IPv4 주소를 IPv6 주소로 변환하거나 그 반대로 변환하여 통신함, 패킷의 앞 부분에 변환 헤더를 추가하여 주소를 변환하여 ㅅ오신하고 수신측에서는 변환 헤더를 제거해서 사용)

* ICMP 프로토콜 -> IP 의 신뢰할수 없는 단점을 보완하기 위한 프로토콜. 에러 발생시 에러 발생 원인을 알려주거나 네트워크상태를 진단해주는 기능을 제공함. (Error-Reporting Message : 전송 중 오류 발생시 에러 메시지를 생성하여 응답 , Query Message: 네트워크 상태 진단), Type 필드 + Code 필드로 구성

* ICMP Error Reporting 메시지
- Destination Unreachable(Type3) : 해당 목적지에 도닥 불가, 목적지 도달 불가 사유에 따라 상세 유형을 Code 로 표기 (1 Host Unreachable -> 최종 단계의 라우터가 목적지 호스트로 패킷 전송에 실패함 , 2 Protocol Unreachable -> 목적지 호스트에서 특정 프로토콜을 사용할 수 없는 경우, 3 Port Unreachable -> 목적지 호스트에 해당 udp 포트가 열려있지 않은 경우 tcp 의 경우에는 포트가 열려있지 않으면 tcp rst 패킷을 반환한다, 4 Fragmentation needed and don't fragment was set -> IP 패킷의 단편화가 필요하지만 IP 헤더에 Don't Fragment 플래그가 설정되어 단편화 할 수 없는 경우 라우터에 의해 반환 됨)

- Redirection(Type 5) : 라우팅 경로가 잘못되어 새로운 경로를 이전 경유지 또는 호스트에게 알려주는 메시지로 ICMP Redirect 공격시 사용한다

- Time Exceeded(Type 11) : 타임 아웃이 발생하여 IP 패킷이 폐기 되었음을 알리는 메시지로 타임 아웃 사유는 Code 를 통해 알 수 있다. (1 Time To Live exceeded in Transit -> IP 패킷이 최종 목적지에 도달하기 전에 TTL 값이 0이 되어 해당 패킷이 폐기 되었음을 알리는 메시지, 1 Fragment reassembly time exceeded -> IP 패

킷 재조합 과정에서 타임아웃이 발생하여 해당 IP 데이터 그램이 모두 폐기되었음을 알리는 메시지 . 일반적으로 IP 데이터 그램의 일부 단편이 전송과정에서 손실될 경우 재조합에 실패하여 발생한다.)

* 주요 ICMP Query 메시지
- Echo Request(Type 8) and Reply(Type 0) : ping 유틸리티 프로그램에 사용되는 메시지로 종단 노드간에 네트워크 및 호스트 상태진단을 목적으로 사용함

* ICMP 리다이렉트 공격 : ICMP 리다이렉트 공격이란 ICMP Redirect 메시지를 이용하여 패킷 경로를 악의적으로 재설정하는 공격을 의미함. ICMP Redirection 메시지를 수신한 호스트는 자신의 라우팅 테이블에 특정 목적지로 나가는 gateway 주소를 변경하는데 공격자는 이를 이용하여 자신이 원하는 형태의 ICMP Redirection 메시지를 만들어 특정 목적지로 가는 패킷을 공격자로 향하도록 함 (ARP Redirection 은 ARP cache table 정보를 변경하여 스니핑하고 ICMP Redirect 는 희생자의 라우팅 테이블을 변조하여 스니핑함) -> ICMP Redirect 옵션을 해제하여 막을 수 있음 (리눅스에서 sysctl -w net.ipv4.conf.all.accept_redirects=0 을 통해 설정 가능)

* TCP 프로토콜 :
- Connection Oriented Protocol (연결지향프로토콜) -> 물리적으로 전용회선이 연결되어 있는 것처럼 가상의 연결 통로를 설정해서 통신하는 방식으로 가상의 연결 통로를 가상회선이라고 함 -> 가산회선 방식 : 물리적으로 전용회선이 연결되어 있는 것처럼 논리적으로 동작하는 방식, 순서제어 ->논리적인 연결통로를 통해 데이터를 주고받음으로써 데이터의 전송순서를 보장해줌, 스트림 기반의 전송 방식 -> 데이터를 임의의 크기로 나누어 연속해서 전송 (정해진 크기로 전송 X)
- Realiable Protocol(신뢰할수 있는 프로토콜) -> 흐름제어(슬라이딩 윈도우사용: 상대방이 수신가능한크기인 윈도우 사이즈 내에서 데이터를 연속해서 전송하는 방식 -> 세그먼트 전송시마다 수신확인응답을 수신한 후 전송하게 되면 왕복시간이 길 경우 단위 시간당 데이터 전송량이 매우 떨어지므로 효율적으로 전송하기 위해 상대방이 받을 수 있는 범위 내에서 연속적으로 전송함) , 오류제어(오류나 누락이 있을경우 재전송을 수행하여 안전한 전송을 보장함), 혼잡제어(데이터 누락이 있을 경우 혼잡상태로 판단하여 전송 상태 조절)

* tcp 프로토콜 구조 : Source Port(16bits), Destination Port(16bits), Sequence Number(32bits), Acknowledgment Number(32 bits), HLEN(4bits), Control Flags (URG -> 긴급 데이터 , ACK -> 수신 확인응답 , PSH -> 송수신 버퍼에 있는 데이터를 즉시 처리 , RST -> 강제 연결 중단 , SYN -> 연결 설정, FIN -> 정상 연결 종료), Windows Size(수신측에서 송신측에 보내는 수신 버퍼의 여유 공간 크기 -> 이것을 통해 흐름제어 가능 , 윈도우 사이즈 내에서는 수신 확인응답인 ACK 를 기다리지 않고 데이터를 연속적으로 전송함) , Checksum, Urgent Pointer(UGR 플래그를 포함하고 있는 경우 사용되는 필드로 긴급 데이터의 위치값을 담고 있다)

* 포트 분류 방식 : 포트는 상위 어플리케이션/서비스/소켓을 식별하기 위한 식별자로 IANA 기구를 통해 관리되고 있음 -> well-know port (0~1023), registered port(1024 ~ 49151 -> DBMS 포트 같은 것들 ...), dynamic port(49142 ~ 65535 -> 일반 클라이언트 포트)

cf. 사용권한에 따라 관리자권한(0~1023)과 일반 사용자 권한(1024~65535)으로 나뉨

* TCP 분할과 재조합 -> MSS(Maximum Segment Size) : tcp 세그먼트 데이터부의 최대 바이트 수를 의미함. 연결 과정에서 상호간에 MSS 정보를 주고 받음 (TCP 옵션 헤더의 MSS 필드) -> MTU 크기에서 IP헤더(20bytes)와 TCP헤더(20bytes)를 빼면 MSS 크기임. Application 계층에서 전달된 데이터는 TCP 계층에서 MSS 크기에 따라 분할이 발생한다. 분할된 세그먼트는 수신 측에서 재조합되어 Application 계층으로 전달 된다.

* 3-Way Handshake(연결 설정 과정)
-> 최초 클라이언트는 서버와 연결 설정을 위한 연결요청 SYN패킷을 보낸다. (이 때 클라이언트는 Active Open, 서버는 Passive Open 에 해당한다)
-> SYN 은 상호간에 순서번호를 동기화하자는 의미임. 상호간의 초기 순서번호(ISN) 은 랜덤한 값으로 시작함
-> 최초 SYN 패킷을 보낸 TCP 상태를 SYN_SENT 상태라고 함
-> 클라이언트의 연결 요청에 대한 수신 확인용 응답 ACK 과 함께 서버에서 클라이언트로 연결 요청을 보내 상호간에 연결 요청을 수행함
-> 수신확인용응답인 ACK 를 하게 되면 반드시 Acknowledgment Number 을 설정하는데 그 의미는 상대방이 다음에 보낼 패킷의 순서번호를 의미함.
-> server의 연결 요청인 SYN 패킷에 대해 수신확인 응답인 ACK 를 전송한 후 최종적으로 연결 설정이 완료 됨.

=> 상태변화 : SYN_SENT -> SYN_RCVD -> ESTABLISHED
=> 패킷 전송 흐름 : SYN (클라이언트) -> SYN+ACK (서버) -> ACK (클라이언트)

* 데이터 송수신 과정 - 재전송 과정 : TCP는 모든 세그먼트 전송시마다 재전송 타이머를 동작시켜 재전송 타임아웃동안 상대방으로부터 ACK가 없으면 송신자는 해당 패킷이 누락된 것으로 판단하여 재전송을 수행함. (혼잡제어 관점에서 재전송 타이머 만료에 따른 재전송이 발생하는 상황은 매우 혼잡한 상태로 판단함)

* 데이터 송수신 과정 - 빠른 재전송 과정 : TCP는 수신 측이 기대했던 순서번호가 아닌 그 이후 순서번호의 세그먼트를 수신하면 즉시 기대하는 순서번호의 세그먼트를 요청하는 ACK 패킷을 전송한다. -> 클라이언트는 중복 ACK 가 두 번 발생할 때까지는 일시적으로 서버에 전달한 세그먼트의 순서가 맞지 않는 상태로 판단하다가 세번째부터는 누락으로 간주하고 재전송을 수행한다. 재전송 타임아웃 발생이전에 중복 ACK가 세번 발생하면 즉시 재전송을 수행하므로 이를 빠른 재전송이라고 한다. 재전송보다 빠른 재전송이 발생할 때 좀 더 덜 혼잡한 상태로 간주한다. (일부 세그먼트만 누락된 상황이므로)

* 4-Way Handshake 연결 종료 과정
-> 클라이언트는 서버와의 연결 설정을 종료하기 위한 연결 종료 패킷(FIN+ACK)을 보낸다. 능동적인 연결 종료 수행을 Active Close, 수동적으로 수행하는것을 Passive Close 라고 함.
-> 클라이언트의 연결 종료에 대한 수신 확인응답 ACK 를 보냄. 서버는 해당 서버 애플리케이션에서 TCP 연결 종료를 할 때 까지 대기한 후 종료되면 클라이언트에 연결 종료 패킷 (FIN +ACK)를 보낸다
-> 서버의 연결 종료 패킷을 수신한 클라이언트는 즉시 연결을 종료하는 것이 아니라 서버에 마지막 ACK 를 보낸 후 2MSL 시간동안 대기한다. (대기하는 이유는 마지막 ACK 응답이 상대방에게 안전하게 전송됨을 보장해주기 위한 것으로 만약 서버가 마지막 ACK 를 수신하지 못했다면 FIN+ACK 재전송이 발생할 것이고 이를 처리하기 위해 일정시간 대기한다)

=> 상태변화 : FIN_WAIT_1 -> CLOSE_WAIT -> FIN_WAIT_2 -> LAST_ACK -> TIMEWAIT -> CLOSED
=> 패킷 전송 흐름 : FIN+ACK (클라이언트) -> ACK (서버) -> FIN + ACK(서버) -> ACK(클라이언트)

* 연결 요청 거부(강제종료)
- 클라이언트 TCP가 연결을 위해 SYN 요청을 전송했으나 서버에 해당 포트가 준비되어 있지 않으면(listen하고 있지 않음) RST+ACK 패킷을 클라이언트에 전송하여 연결 요청을 거부하게 됨. RST_ACK 패킷을 수신한 클라이언트는 즉시 종료 상태가 됨

=> 상태 변화 : SYN -> CLOSED
=> 패킷 전송 흐름 : SYN -> RST+ACK

* 연결중단(abort)
- 연결 상태에 있는 클라이언트가 연결을 즉시 중단해야할 필요가 있을 경우 서버에 RST+ACK (상대방으로 수신한 세그먼트에 Acknowledgement Number 가 설정되어 있지 않은 경우) 또는 RST(상대방으로부터 수신한 세그먼트에 Acknowledgement Number 필드가 설정되어 있는 경우) 를 전송함.

=> 상태변화 : ESTABLISHED -> CLOSED
=> 패킷 전송흐름 : RST + ACK

* TCP 세션 하이재킹 : 케빈 미트닉이 사용했던 공격 방법의 하나로 TCP 세션 관리 취약점을 이용한 공격
-> TCP 는 연결 과정을 통해 상호간에 세션을 생성한 후 IP 와 Port, SegmentNumber 와 Acknowledgment Number 를 통해 상호인식을 함
-> TCP 하이재킹은 위와 같은 세션 식별정보를 공격자가 위조하여 세션을 탈취하는 공격. 공격자는 정상적인 사용자의출발지 IP와 Port로 위조하고 Sequence Number를 예측하여 세션을 탈취함

=> ARP 스푸핑을 통해 둘 사이의 TCP 식별 정보를 탈취하기 위한 스니핑 진행 -> IP 스푸핑을 통해 서버에 패킷 전달 -> 서버는 ACK 응답을 전달 (공격자가 스푸핑한 정상 클라이언트에게 전달하게 되므로 클라이언트입장에서는 데이터를 보내지 않았는데 Acknowledgment number가 증가한 응답을 받게 되는 상황이 발생함) -> 클라이언트는 잘못된 응답에 대해 교정하기위한 ack 를 서버에 재전송 -> 이과정이 반복되면서 ack 메시지가 대량 발상해게 됨 -> ack storm 발생 -> 공격자에 의해 sequence number 와 acknowledgement Number가 조작된 것이기 때문에 정상 클라이언트와 서버간에는 ack 를 보내 교정할 수 없음 -> 공격자는 최종적으로 정상 클라이언트에게 RST 메세지를 전달하여 연결을 강제로 종료하고 자신은 서버와의 연결을 유지함

* UDP 프로토콜 : 비연결형 프로토콜로 데이터그램 전송시마다 주소 정보를 설정해서 전송하고, 순차적 전송을 보장하지 않음. 데이터 그램 방식의 데이터 크기가 정해진 전송방식을 사용, 신뢰할 수 없는 프로토콜로 오류/혼잡제어를 수행하지 않음 -> 실질적으로 IP 기반에 포트 정보를 이용하여 상위 송수신 애플리케이션을 식별해주는 역할만 진행, 단순하고 가벼운 프로토콜로 전송속도가 빠른 장점이 있음, 비신뢰적이라 대량 데이터의 송수신은 부적절하지만 주로 한 번의 패킷 송수신으로 완료되는 서비스에 많이 사용함 (dns - 53/udp, ntp - 123/udp, dhcp - 67,58/udp)

* udp 프로토콜 구조 : source port, destination port, total length, checksum (전체 데이터 그램에 대한 오류를 검사하기 위한 필드)

* 네트워크 관리 명령어
- ping 명령어 : 종단 노드 간에 네트워크 상태를 관리하기 위한 명령어, Target 시스템에 대한 접근성, 해당 구간에 대한 네트워크 속도 및 품질을 검사하기 위한 명령
- ICMP Echo Request(Type:8)와 ICMP Echo Reply(Type:0)메시지 이용 -> 윈도우는 -n(패킷전송횟수), -l(패킷 크기 설정 default 32 bytes), 리눅스는 -c(패킷 전송횟수 설정), -s(패킷 크기 설정 default 56 bytes)

* traceroute(목적지 호스트 포트로 udp 패킷의 ttl 값을 1씩 증가시키면서 진단)/tracert(윈도우, ICMP Echo Request 패킷의 TTL 값을 1씩 증가시킴) 명령 : 종단 노드 사이에 있는 여러 중계노드 각 구간에 대한 네트워크 상태를 관리하기 위한 명령어로 네트워크 라우팅 문제점을 찾아내는 목적으로 많이 사용 -> 최종 목적지 노드에 도달하는데 경유하는 중계 노드의 개수, IP주소, 응답시간등을 파악할 수 있음. 각 구간에 대한 접근성 및 네트워크 속도를 검사함

* 보안상의 이유로 라우터에서 ICMP 응답을 주지 않는 경우 다수 -> traceroute 명령 수행시 * 로 표시되면 응답이 없는 경우거나 실제 해당 구간에 문제가 발생함

* 라우터는 패킷의 생존 시간 계산을 위해 패킷 수신시 TTL 을 1 씩 감소시킴. TTL 이 0이 되면 TTL 초과로 판단하여 해당 패킷을 폐기한 후 ICMP Time Exceeded 패킷을 최초 출발지로 보냄.

* 최종 목적지에 udp 패킷이 도달하면 해당 udp 포트가 닫혀 있으므로 ICMP Destination Unreachable 패킷이 반환되며 최초 출발지 호스트는 이 정보를 이용하여 최정 목적지 호스트에 도달함을 알 수 있음

*netstat 명령어 : 네트워크 관련 다양한 상태정보를 관리할 수 있는 명령어
- a 옵션 : 모든 소켓 상태 정보 (ESTABLISHED 뿐만 아니라 LISTEN등 모든 소켓 출력)
- i 옵션 : 네트워크 인터페이스 정보
- r 옵션 : 시스템 라우팅 테이블정보
- s 옵션 : 프로토콜별 통계정보
- -t 옵션 : TCP 소켓을 출력하라는 옵션으로 tcp 중 ESTABLISHED만 출력함. (cf. u는 UDP)
- n 옵션 : 네트워크주소를 숫자 형식으로 출력함.
- p 옵션 : 해당 소켓의 프로세스명/pid정보를 출력하는 옵션
- i 옵션 : 네트워크 인터페이스 정보를 확인할 수 있음 (RX 는 수신, TX는 송신(전송)을 의미하며 OK 는 오류 없이 송수신한경우, ERR는 오류발생한경우, DRP는 폐기, OVR은 과도한 양의 수신 패킷에 의한 오버플로우 발생으로 폐기된 패킷 수를 의미한다.

* netstat 명령어 사용시 출력 필드의 의미
- proto : 사용한 프로토콜의 종류
- recv-Q : 원격 호스트로부터 수신 버퍼에 저장한 데이터의 크기
- Send-Q : 원격 호스트로부터 전송하기 위해 송신 버퍼에 저장한 데이터의 크기
- Local Address : 로컬 호스트의 소켓 주소
- Foreign Address : 원격 호스트의 소켓 주소
- State : 소켓 상태

* ifconfig 명령(유닉스/리눅스) : 유닉스/리눅스시스템에서 네트워크 인터페이스 설정정보를 조회하거나 IP나 서브넷마스크 등의 설정을 변경할 때 사용한다. -> ifconfig eht1(인터페이스이름) promics 를 사용해서 promiscuous 모드로 전환할 수 있음. 이것은 /var/log/messages 에 기록되는데, promiscuous는 외부 침입자에 의한 불법적인 스니핑 목적으로 전환될 가능성이 있으므로 주의가 필요, -promics 를 사용하면 설정을 해제 시킬 수 있음

* Metric(메트릭) : 라우팅 경로의 효율성(우선순위)를 나타내는 값으로 이 값이 클수록 비용이 크다. -> 메트릭이 클수록 우선순위가 낮아진다.

* 포트 스캐닝 : 침입 전 취약점을 분석하기 위한 사전 작업중의 하나로 공격자가 침입 전 대상 호스트에 어떤 포트가 활성화되어 있는지 확인하는 기법임 . 포트스캐닝 -> nmap

* nmap 포트 스캐너 사용 방법 - Scan Type

- -sS : TCP SYN(Half-Open) Scan : TCP 포트 오픈 여부를 확인하는 스캔
- -sT : TCP Connect(Open) Scan : TCP 포트 오픈 여부를 확인하는 스캔
- -sU : UDP Scan : UDP 포트 오픈 여부를 확인하는 스캔
- -sF : TCP FIN Scan : TCP FIN 제어비트 패킷을 이용한 스캔
- -sX : TCP Xmas Scan : TCP FIN, PSH, URG 제어비트를 조합한 패킷을 이용한 스캔

- -sN : TCP Null Scan : TCP 제어비트 설정이 없는 NULL 패킷을 이용한 스캔
- -sA : TCP ACK Scan : 방화벽 룰셋(필터링 정책)을 확인하기 위한 스캔
- -sP : Ping(icmp/icmp echo) Scan : Ping을 이용해 호스트 활성화 여부를 확인하는 스캔
- -D : Decoy 스캔 : 실제 스캐너 주소 외에도 다양한 주소로 위조하여 스캔하는 방식
- -b : TCP FTP Bounce Scan, -b <FTP bounce proxy>

* nmap 포트 스캐너 사용 방법 - Port Option
-> -p 뒤에 포트번호, 서비스명을 기재하여 스캔할 수 있음,
-> -p 뒤에 포트번호를 기재할 때 콤마를 사용하여 한번에 여러 포트도 스캔할 수 있음
-> -p 포트범위를 기재하여 일정 범위로 포트를 스캔할 수 있음. 1-1023 와 같은형태
-> -pT:21,23,110,U:53 형식으로 TCP와 UDP를 분리해서 포트를 스캔할 수 있음

*nmap 포트 스캐너 사용 방법 - Output Option
-> -v : 상세 내역 출력
-> -d : Debugging
-> -oN <file> : 결과를 일반 파일 형식으로 출력
-> -oX <file> : 결과를 XML파일 형식으로 출력
-> -oG <file> : 결과를 Grepable(grep, awk 등 분석이 용이한) 파일형식으로 출력
-> -oA <Directory> : 일반(.nmap), XML(.xml), Grepable(.gnmap) 파일로 출력

* nmap 포트 스캐너 사용 방법 - 기타 Option
-> -O : 영문 대문자 O, 대상 호스트의 운영체제 정보를 출력
-> -F : 빠른 네트워크 스캐닝
-> T0 ~ T5 : 숫자가 커질수록 빨라짐 (T5가 가장빠르고 T0가 가장느림)

* nmap 포트 스캐너 사용 방법 - Target
-> hostname 지정 : ex) www.algisa.com
-> IP address, Network 등 가능 : ex) 192.168.159.151, 192.168.159.0/24, 192.168.159.100-150

* TCP Connect(Open) 스캔 : 일반 사용자 권한으로 TCP포트 오픈 여부를 확인하기 위해 connect 시스템 호출(tcp 통신에서 connect시스템 호출은 원격 호스트와 tcp 3 hand shacking을 수행하여 데이터의 송수신이 가능하도록 해주는 기능을 수행)을 이용하는 방식으로 스캔 대상 포트별로 정상적인 TCP 연결설정을 수행하여 스캔하는 방식이다. 일반 사용자 권한으로 사용할 수 있는 시스템 호출을 이용하는 스캔 방식이며 TCP 연결과정을 완전하게 수행하므로 시스템 로그에 스캔한 흔적이 남는다. -> TCP Connect Scan 이므로 -sT 로 암기

=> target 호스트의 대상 포트로 syn 패킷 전송, 전송 후 포트 오픈 여부에 따라 각각 오픈(syn+ack)/닫힘(rst+ack) 응답을 수신 -> 열린 상태의 경우 ack 를 다시 전송하여 연결을 완료.
=> 연결이 완료 된 후 포트 오픈 여부를 확인했기 때문에 연결을 즉시 중단하기 위해 RST+ACK 패킷을 전송함
=> tcp 연결 설정이 이루어지기 때문에 대상 호스트의 시스템 로그에 스캔을 시도한 ip 주소가 남음

=> target host 의 포트가 방화벽에 의해 차단되고 있다면 방화벽 차단 정책에 따라 응답이 없거나 ICMP(Destination Unreachable) 메세지 응답을 받을 수 있다. 일반적으로 보안상의 이유로 응답없이 설정한다. iptables 방화벽의 경우 DROP 차단 정책을 사용하면 해당 패킷을 폐기한 후 아무런 응답을 하지 않고 REJECT 차단 정책을 사용하면 해당 패킷을 폐기한 후 설정된 icmp 메세지를 전송함 (drop -> 응답없음, reject -> icmp 응답 있음)

* TCP SYN(Half-Open) 스캔 : 관리자 권한으로 TCP 패킷 자체를 직접 조작하여 TCP 포트 오픈 여부를 판단하는 스캔 방식이다. 포트 스캔 과정에서 TCP 패킷 헤더의 제어비트를 조작함. 3-way-handshaking을 완전하게 수행하지 않기 때문에 Half-Open 스캔이라고 표현 -> 스캔 대상 시스템에 로그가 남지 않아 공격자는 자신의 IP를 노출시키지 않으면서 스캔할 수 있음 (흔적을 남기지 않음) -> 스텔스 스캔 (TCP SYN scan, TCP FIN Scan, TCP Null Scan, TCP Xmas Scan) -> TCP SYN Scan 이니까 -sS 로 암기

=> 스캔 대상 포트로 SYN 전송 후 ACK+SYN 응답이 수신되면 RST 를 바로 호출하여 연결을 즉시 중단함, 포트가 닫혔을 경우에는 RST+ACK 응답 수신

=> target
host 의 포트가 방화벽에 의해 차단되고 있다면 방화벽 차단 정책에 따라 응답이 없거나 ICMP(Destination Unreachable) 메세지 응답을 받을 수 있다. 일반적으로 보안상의 이유로 응답없이 설정한다. iptables 방화벽의 경우 DROP 차단 정책을 사용하면 해당 패킷을 폐기한 후 아무런 응답을 하지 않고 REJECT 차단 정책을 사용하면 해당 패킷을 폐기한 후 설정된 icmp 메세지를 전송함 (drop -> 응답없음, reject -> icmp 응답 있음)

* TCP FIN/NULL/Xmas 스캔 : 관리자 권한으로 TCP 패킷 자체를 직접 조작하여 TCP 포트 오픈 여부를 판단하는 스캔 방식, 스텔스 스캔방식(TCP세션 연결을 생성하지 않고 스캔하는 방식, 스캔 대상 호스트에 로그를 남기지 않는 기법), FIN 표준의 특성을 이용하여 포트 오픈 여부를 확인함(닫힌 포트로 RST 이외의 패킷을 수신한 경우 RST 패킷으로 응답함, 열린 포트로 SYN, ACK 또는 RST 이외의 패킷을 수신한 경우 이를 폐기하고 응답하지 않음)
- TCP FIN 스캔 : FIN 제어비트만 설정하여 스캔하는 방식으로 TCP 표준에서 연결 종료 패킷은 FIN+ACK 제어 비트를 사용 -> -sF
- TCP NULL 스캔 : 제어비트를 설정하지 않고 스캔하는 방식으로 TCP표준에서 사용하지 않는 설정 -> -xN
- TCP Xmas 스캔 : URG, PSH, FIN 제어비트를 설정하여 스캔하는 방식으로 TCP 표준에서는 사용하지 않는 설정 -> -sX

Q. TCP 표준에서 사용하지 않는 스캔 -> NULL/Xmas 스캔

cf. TCP 표준에서 SYN, ACK, RST 이외의 패킷을 수신시 폐기하므로 FIN, NULL, Xmas 스캔은 포트가 열려 있으면 응답이 오지않음 (나머지는 SYN+ACK) . 닫혀 있으면 RST를 제외하고 모두 RST+ACK ! (헷갈릴 수 있는데 닫혀있을 때 응답이옴 !!)
-> 응답이 없으면 열려 있거나 (폐기당해서) filtered 상태고 응답이 있으면(RST+ACK) 닫혀 있다.

cf. 포트 오픈 스캔시 사용하는 툴 : wireshark / nmap

* TCP ACK 스캔 : Target 호스트의 포트 오픈 여부를 판단하는 것이 아니라 방화벽 룰셋(필터링정책)을 알아내기 위한 스캔 방식, ACK 제어비트만 설정한 패킷을 전송 -> 방화벽에 의해 차단되면 응답이 없거나 ICMP Destination unreachable 응답 수신, 방화벽에 의해 허용되면 RST 수신(포트오픈 여부는 중요하지 않음. 방화벽에 의해 허용 되었는데 ACK 무조건 RST)

cf. TCP표준에서 열린 포트에 ACK 를 수신한 경우 RST로 응답하고, 닫힌 포트에 ACK를 수신한 경우(RST이외의 패킷)에도 RST로 응답한다.

* UDP 스캔 : UDP 포트 오픈 여부를 판단하는 스캔방식으로 닫힌 UDP 포트로 패킷 수신시 ICMP 에러 메시지로 응답하는 특성을 이용 (Destination Unreachable . Port Unreachable) -> 오픈되어 있을 땐 UDP 로 응답이 오거나 응답이 없음 / 닫혀있을 땐 ICMP Unreachable 메시지 수신 -> UDP 라서 -sU 로 암기 , 필터일 경우 TCP Connect 스캔과 동일하게 응답이 없거나 ICMP 에러 메시지 응답을 받을 수 있음

* Decoy 스캔 : 다양한 포트 스캔을 수행할 때 스캔을 당하는 Target host 에서 스캐너 주소를 식별하기 어렵도록 실제 스캐너 주소 외에 다양한 위조된 주소로 스캔하는 방식 -> 다양한 IP로 스캐너 주소를 위조하여 스캔
-> -D 옵션을 사용

서비스 거부 공격 (Denial of Service) : 서비스 거부 공격은 공격 대상 시스템이 정상적인 서비스를 할 수 없도록 서비스를 마비시키는 공격을 의미함 -> 가용성을 떨어트림 (Availability)
- 파괴 공격, 시스템 자원 소진 공격, 네트워크 자원소진 공격으로 나뉨
- Ping of Attack, Land Attack, Smurf Attack, TearDrop Attack, Tiny Fragment, Fragment Overlap

cf. 서비스 거부와 분산 서비스 거부 공격의 차이점 : 서비스 거부는 공격자가 단일 컴퓨터를 이용하여 공격하는 형태, 분산서비스는 분산된 다수의 컴퓨터 또는 장치들을 이용하여 공격하는 형태 (Dos, DDos)

* Ping Of Death Attack : 대량의 IP Fragment 를 생성하여 재조합 부하 / 재조합 버퍼 오버 플로우를 공격 시킴 -> ping 명령을 통해 ICMP(or ICMP Echo Request) 패킷을 정상적인 크기보다 아주 크게 만들어 전송하면 MTU에 의해 다수의 IP단편화가 발생함

cf. MTU는 물리적인 네트워크 프로토콜 프레임의 데이터부의 최대크기를의미함 (이더넷의 크기는 IP 헤더 20byte 를 제외하고 1480byte)

-> 대응책: 패킷 중 분할이 일어난 패킷을 공격으로 의심하여 탐지함 (반복적으로 들어오는 일정 수 이상의 ICMP 패킷을 무시하게 설정)

* Land Attack : Land 자체가 착륙하다 이외에도 나쁜 상태에 빠지게 하다라는 의미가 있음 -> 시스템을 나쁜 상태에 빠지게 함 -> 공격자가 출발지와 목적지가 같은 IP 패킷을 만들어 공격 대상 시스템에 보냄으로써 수신자가 자기자신에게 응답을 보내 무한 루프상태에 빠지도록하여 시스템의 자원을 소모시키는 형태의 도스 공격

-> 대응책 : 출발지와 목적지 IP 주소가 동일한 패킷의 경우 모두 폐기 처리, 침입차단시스템, 라우터 등 패킷 필터링 장비를 통해 출발지 IP와 목적지 IP가 같은면 차단하도록 설정함

* Smurf Attack : 출발지 IP를 희생자 IP로 위조한 후 증폭 네트워크로 ICMP Echo Request를 브로드캐스트함으로써 다수의 ICMP Echo Reply가 희생자에게 전달되어 서비스 거부를 유발시키는 공격 기법 -> IP스푸핑, 증폭네트워크 사용

cf. Directed BroadCast : IP 주소의 호스트 ID비트를 모두 1로 설정하여 브로드캐스트 하는 방식

-> 대응책 : 스머프 공격의 특성상 공격이 시작되면 단시간에 다수의 ICMP Echo Reply 패킷을 희생자에게 전송하므로 동일한 ICMP Echo Reply 패킷이 발생한다면 해당 패킷들을 침입차단시스템으로 모두 차단 시킨다. -> ICMP Echo Reply 패킷 다량 발생은 스머프 공격 !, 증폭 네트워크로 사용되는 것을 막기 위해 외부 네트워크로부터 자신의 네트워크로 들어오는 Directed Broadcast 패킷을 허용하지 않도록 라우터 설정을 하도록함 (스머프 공격 자체가 증폭 네트워크를 이용하기 때문에, 이용할 증폭 네트워크 자체를 차단하는 방식. no ip directed-broadcast 명령어를 사용하여 라우터 설정을 바꿀 수 있음, 또는 브로드캐스트 주소로 전송된 ICMP Echo Request 메시지에 대해 응답하지 않도록 시스템 설정을 한다.

* Treadrop Attack : IP 패킷의 재조합 과정에서 조작된 단편의 오프셋 정보로 인해 수신시스템에 오류나 부하가 발생하도록 만드는 도스 공격을 말한다. 공격자는 IP fragment offset 값을 서로 중첩되도록 조작하여 전송하고 이를 수신한 시스템이 재조합하는 과정에서 오류나 부하가 발생, 시스템의 기능을 마비시키는 공격 방식이다. 패킷 fragment관련 헤더 값을 조작하는 유사한 공격으로 Bonk. Boink 가 있다.

-> fragment 헤더 값 조작 -> Treadrop Attack, Bonk, Boink

* IP 단편화의 취약점을 이용한 우회 공격 : 패킷 필터링 장비를 우회하는 대표적인 공격 기법에는 Tiny Framgent(작은 단편), Fragment Overlap(단편 중첩) 이 있다 -> 침입차단시스템 등을 우회하여 허용하지 않는 공격 대상 시스템의 서비스에 접근하기 위한 공격 (IP단편의 오프셋을 조작한다는 공통점은 있지만 Dos 가 아님)

-> IP단편의 오프셋 조작하는데 Dos면 Teardrop Attack, 아니면 Tiny Fragment(최초의 단편을 아주 작게 만들어서 패킷 필터링 장비를 우회하는 공격 기법, 목적지 서버에서 단편들이 재조합되어 공격자가 원하는 목적지 포트로 연결됨)/Fragment Overlap(IP단편의 오프셋을 조작하여 첫 번째 단편의 일부분을 두번째 단편이 덮어 쓰도록함, 두번째 단편의 목적지 포트가 첫 번째 단편의 목적지 포트를 덮어쓸 수 있도록 두 번째 단편의 오프셋을 조작함)

-> 대응책 : 단편화된 패킷들을 재조합하여 IP 단편화를 이용한 우회 공격의 탐지가 가능한 패킷 필터링 장비(방화벽, 침입탐지시스템 등)을 적용함.

* 분산 서비스 거부 (DDos: Distributed Denial of Service) : 분산된 다수의 좀비 PC/디바이스에 의해 공격대상 시스템의 서비스를 마비시키는 공격 형태
- 공격자 : C&C 서버에 공격 명령을 전달하는 해커의 컴퓨터 = Bot Master
- 명령제어(C&C/Command & Control) : 공격자로부터 직접 명령을 전달 받는 시스템. 전달 받은 명령은 관리하는 다수의 좀비 PC/디바이스에 전달함
- 좀비 : C&C 서버로부터 전달받은 명령을 실행하여 공격대상에 실제 공격을 수행하는 PC/디바이스 = Bot, Agent, Slave
- 공격대상 : 공격의 대상이 되는 시스템

-> 공격자가 C&C 서버 구축 -> 봇을 생성(악성프로그램배포) -> 봇이 C&C서버에 접속하여 감염 PC로 전환하여 봇넷 구축 -> 공격자가 C&C 서버를 통해 봇에 명령 전달 -> 봇은 명령에 따라 다양한 공격을 수행하며 스스로 다른 PC로 봇의 전파를 시도함

* 봇/봇넷 : 봇은 소프트웨어적 로봇을 줄임말로 보안상 결함을 이용해 원격에서 해당 시스템을 제어할 수 있는 프로그램을 의미함. 이런 악성 봇에 감염된 PC 디바이스를 좀비PC/디바이스라고 한다.
-> 봇은 일반적으로 웜/바이러스,백도어,스파이웨어,루트킷 등 다양한 악성 코드의 특성을 복합적으로 가짐

-> 봇은 공격자의 명령에 의해 활동하며 정보유출,스팸메일발송,디도스공격,트래픽 스니핑, 키 로깅등 다양한 형태의 공격을 수행함
-> 봇넷은 악성 소프트웨어인 봇에 감염된 다수의 좀비 PC/디바이스로 구성된 네트워크를 의미함. 좀비들은 C&C서버와 직접 통신하거나 좀비들 간에 서로 통신을 수행하면서 공격자의 명령을 수행함 (명령/제어를 위해 사용하는 프로토콜에 따라 IRC봇넷, HTTP 봇넷, P2P봇넷으로 분류 / 네트워크 구성에 따라 중앙 집중형 방식(IRC봇넷, HTTP봇넷)과 분산형(P2P)으로 나뉨)

cf. IRC : 인터넷상에서 채팅을할 수 있도록 고안된 프로토콜. 봇 마스터는 IRC 서버를 C&C 서버로 활용함

* 중앙집중형 명령/제어 방식 (C&C 방식) : 초기에 IRC 봇넷이 많이 있었음 나중에 HTTP 기반으로 진화, C&C 서버가 탐지 및 차단되면 전체 봇넷이 중단될 가능성이 있음 -> 대표적으로 IRC봇넷(Rbot), HTTP봇넷(Robax)이 있음

* 분산형 명령/제어 방식 : 참여 멤버들이 모두 C&C 역할을 하여 중앙관리를 위한 별도의 도메인 및 C&C 서버가 불필요함. 탐지 및 차딘이 어려움 -> 대표적으로 P2P봇넷(Storm, Peacomm 등)이 있음

* DNS 싱크홀 서비스 : C&C서버 대신 싱크홀 서버로 우회시켜 더 이상 해커로부터 조종 명령을 받지 않도록 해주는 시스템/서비스를 말한다. 한국인터넷진흐원에서 국내 주요 ISP업체 및 가입기관과의 협력을 통해 DNS싱크홀을 운영하고 있음

-> 일반적으로 봇넷을 구성하는 좀비 PC나 랜섬웨어 등의 악성코드(멀웨어)등은 C&C서버에 접속하는 과정에서 C&C 서버 도메인에 대한 질의를 수행하므로 C&C 서버 도메인이나 IP주소등이 알려지면 이를 블랙리스트로 등록하여 탐지 및 차단을 수행한다.

* 봇넷의 보안장비 우회 기법 : Fast Flux, DGA, Domain Shadowing
- Fast Flux : 하나의 C&C 서버 도메인에 다수의 IP주소를 할당하여 DNS질의 시마다 지속적으로 IP주소가 변경되도록 하는 기법
- DGA(Domain Generation Algorithm) : 약속된 규칙에 따라 C&C서버 도메인을 지속적으로 동적 생성하여 도메인 기반의 탐지 및 차단을 우회함, 컨피커 웜에 의해 DGA 기법이 처음 알려졌으며 Locky(시스템 날짜 기반으로 도메인명 생성), WannaCry 랜섬웨어 등에서 사용 됨
- Domain Shadowing : 알려진 합법적인 도메인의 서브 도메인을 C&C 서버 도메인으로 사용함 (합법적인 도메인을 소유하고 있는 도메인 관리자의 개인정보를 탈취하여 도메인 소유자 몰래 많은 서브 도메인을 등록해놓고 사용함), DBD(Drive By Download) 공격 도구인 앵글러 익스플로잇 도구에서 탐지 회피를 위한 기술로 사용되어 알려짐
- 주로 드라이브 바이 다운로드 공격에서 악성코드 유포지로 흘러가는 길목에 사용되는 경유지 도메인을 서브 도메인으로 사용함

* DDos 공격 유형 - 대역폭 소진 공격
- UDP/ICMP Flooding, DNS Query Flooding, TCP Flooding(SYN Flooding, SYN+ACK Flooding), IP Flooding(Land Attack, Tear Drop, HTTP Continuation -> HTTP 헤더 없이 데이터만 채워서 보내는 공격)
- 3~4계층 프로토콜에서 사용 (IP, ICMP, IGMP, UDP, TCP)
- 회선대역폭 고갈, 동일 네트워크를 사용하는 모든 서비스에 대해 접속 장애 발생
- 네트워크 인프라 대상으로 공격

* DDos 공격 유형 - 서비스 마비 공격
- HTTP Get Flooding(Get Flooding, CC Attack), HTTP Header/Option Spoofing(Slowris, Pyloris), TCP Traffic Flooding(TCP session, SYN Flooding, TCP Slow Read), Other L7 Service Flooding(Hash Dos, Hulk Dos, FTP/SMTP Attack)
- 7 계층 프로토콜에서 사용 (HTTP, DNS, SMTP)
- HTTP 서버 과다 접속 으로 인한 장애 발생, 공격 대상 시스템만 피해
- 웹서버/정보보호 장비 대상으로 공격

* UDP/ICMP Flooding 공격 : 공격자는 다량의 UDP/ICMP 패킷을 서버로 전송하여 서버가 보유한 네트워크 대역폭을 소진시켜 다른 정상적인 클라이언트의 접속을 원활하지 못하도록 유발시킴
* DNS Query Flooding 공격 : 공격자는 UDP 프로토콜 기반의 서비스를 제공하는 DNS에 대해 DNS쿼리 데이터를 다량으로 서버에 전송하여 DNS의 정상적인 서비스를 방해함

* TCP SYN Flooding: 공격자는 다량의 SYN패킷을 서버로 전달하여 서버의 대기큐를 가득 채워 새로운 클라이언트의 연결 요청을 무시하도록하여 장애를 유발 시킴 -> connection queue(backlog queue) 를 꽉 차게 만들어 더 이상 새로운 연결 요청을 받을 수 없도록 하는 공격 (SYN -> SYN+ACK -> ACK 순으로 소켓 연결이 성립하는데 ACK 를 주지않아 connection queue 만 계속 참), 공격자는 incomplete connection queue를 소진시키기 위해 출발지 IP 를 도달불가능한 IP로 위조한 SYN 요청을 보내 서버측의 SYN+ACK 응답이 발생하지 않도록 만든다 (SYN_RECV 상태만 많음)

-> 완전한 3 Way handshaking이 이루어지지 않는다면 Backlog queue가 소비되지 않도록 설정함 (SYN Cookie 설정 : TCP표준명세에 정의된 내용으로 연결 요청 클라이언트의 유효성을 확인하는 방법), sysctl -w net.ipv4.tcp_syncookies=1
-> 방화벽 또는 DDos 대응 장비를 이용하여 동일 Client의 연결요청에 대한 임계치 설정을 통해 과도한 연결 요청이 발생하는 것을 차단한다.
-> Fist SYN Drop 설정 : 연결 요청 패킷을 보내는 클라이언트가 실제로 존재하는지 파악하는 방법, 클라이언트로 부터 전송된 첫 번째 SYN은 Drop하여 재요청 패킷이 도착하는지 확인하여 출발지 IP가 위조되었는지 파악함 (대부분은 다량의 SYN 요청을 생성만하고 패킷 Drop시 재전송을 수행하지 않음)
-> Backlog queue의 크기를 늘려줌. 엄청 효과적이진 않음, sysctl -w net.ipv4.tcp_max_syn_backlog=1024 / ndd -set /dev/tcp tcp_conn_req_max_q0 1024
-> SYN+ACK에 대한 대기시간을 줄인다.

* TCP Flag Flooding : TCP의 Flag값을 임의로 조작하면 SYN,ACK,FIN,RST와 같이 여러 형태의 패킷을 생성할 수 있으며 서버는 이러한 패킷을 수신하는 경우 해당 패킷을 검증하기 때문에 서버 자원을 소모시킴

* TCP Session Flooding : TCP 3 hand shaking 과정을 과도하게 유발함으로써 서비스의 과부하를 유발시키는 공격

* HTTP Continuation : 서버로 전달되는 패킷에 HTTP 헤더 없이 Data만 채워 웹서버가 지속적으로 데이터 수신을 위해 TCP 자원을 사용하도록 하는 공격

* HTTP GET Flooding : 공격자는 동일한 동적 컨텐츠에 대한 HTTP GET URL 을 반복 요청하여 웹서버가 URL에 해당하는 데이터를 클라이언트에게 회신하기 위해 서버 자원을 사용하도록 하는 공격

-> 패킷 캡처 도구인 ngrep 사용가능
cf. ngrep : L7 계층 프로토콜 패킷의 데이터부를 ASCII 형식으로 보고자 할 때 유용한 패킷 캡처 도구 (ngrep -qtW byline | grep GET)
-> cat access_log-20160214 | grep "GET /home/index.php" | awk '{print $1}' | sort | uniq -c | sort -rn

-> awk '{print $1}' : grep 한 행중에 첫번째 컬럼을 출력
-> sort : 오름차순으로 정렬
-> uniq -c : 연속된 중복행을 제거 (uniq), 중복된 행의 개수를 출력(c)
-> sort -rn : 역순으로 정렬(r)하되 정렬할 컬럼 값을 숫자형식으로 보고 정렬(n)

* HTTP GET Flooding with Cache-Control(CC Attack) : 공격자는 HTTP메시지의 캐시옵션을 조작하여 캐싱 서버가 아닌 웹서버가 직접 처리하도록 유도하여 캐싱 서버의 기능을 무력화하고 웹서버의 자원을 소모 시킴

* Slow Http Post Dos(rudy) : HTTP POST 메소드를 이용하여 서버로 전달할 대량의 데이터를 장시간에 걸쳐 분할 전송하면 서버는 POST 데이터가 모두 수신하지 않았다고 판단하여 연결을 장시간 유지하게 함

-> 클라이언트는 HTTP 요청을 통해 데이터를 웹서버로 전달하고자 할 때 POST 방식을 사용하고, 메시지의 유형과 크기 정보를 전달하기 위해 Content-Type, Content-Length 필드를 사용함. 공격자는 Content-Length 필드를 비정상적으로 크게 설정한 후 매우 소량의 데이터를 지속적으로 천천히 웹서버에 전송하면 웹서버는 Content-Length 헤더 필드에 명시된 크기만큼 데이터를 모두 수신하기 위해 연결 상태를 유지하면서 대기하게 됨. 패킷 분석을 하면 메시지 헤더부가 정상적으로 0d 0a 0d 0a 로 끝나므로 Slowloris 공격과 무관하다는 것을 알 수 있음

* Slow HTTP header Dos(Slowloris) : 웹서버는 HTTP 메시지의 헤더 부분을 먼저 수신하여 이후 수신할 데이터의 종류를 판단하게 되는데 헤더 부분을 비정상적으로 조작하여 웹서버가 헤더 정보를 구분할 수 없도록 하면 웹 서버는 아직 HTTP 헤더 정보가 모두 전달되지 않은 것으로 판단하여 연결을 장시간 유지함

-> HTTP 요청 메시지는 Request Line, Request Header, Empty Line, Message Body 로 구성되어 있음 . 각 헤더 필드는 개행을 통해 구분됨. 개행은 CRLF (16진수헥사값으로 : 0x0d0a) , 마지막 헤더 필드에 대한 개행처리가 되고 나면 요청 헤더와 바디를 구분하기 위해 빈라인으로써 개행이 한번더 추가 됨. 그런데 이 빈라인을 추가하지 않으면 웹서버는 요청 헤더부를 모두 수신해야 요청 메시지 처리가 가능하기 때문에 이를 모두 수신할 때 까지 연결 상태를 유지하면서 대기함

-> 다량의 트래픽을 발생시키는 DDos 공격 기법과는 달리 웹서버와의 연결 상태를 지속시키는 방식이기 때문에 연결자원을 소진시킬 정도의 트래픽만이 필요하므로 저대역폭 공격이라는 특징을 가짐

* Slow HTTP Read Dos : 공격자는 웹서버와 TCP연결 시, TCP 윈도우 크기 및 데이터 처리율을 감소시킨 후 HTTP 데이터를 송신하여 웹서버가 정상적으로 응답하지 못하도록 Dos 상태를 유발함

-> TCP의 흐름제어는 연결된 상호 간에 수신 가능한 양만큼만 데이터를 전송하는 제어방식을 의미한다. 즉 수신측의 수신버퍼에 충분한 여유 공간이 없다고 송신 측에게 알려주면 송신 측은 수신측에서 여유 공간이 생겼다고 알려줄 때 까지 대기함으로써 흐름제어를 하게 된다. TCP 헤더의 Window 필드는 수신측에서 수신 가능한 여유 공간의 크기를 담아서 송신측에게 전달하는 헤더 필드로, 수신 측에서 수신 버퍼에 여유 공간이 0이 되면 Window 필드를 0으로 설정한 Zero Window Packet 을 전달하고 이를 수신한 송신측에서는 일정시간 대기 후 수신 측 상태를 확인하기 위한 Zero Window Probe Packet을 전달한다. 공격자는 이러한 TCP 흐름제어 특성을 이용해서 HTTP 요청을 보낸 후 Window 크기를 조작하여 0인 Zero Window Packet 을 지속적으로 서버 측에 전달하여 서버가 요청에 대한 응답메시지를 전송하지 못하고 연결을 지속적으로 유지하도록 한다. 이런 방식으로 연결을 지속시키게 되면 대상 웹서버의 연결 자원이 모두 소진되어 정상적인 요청을 받을 수 없는 상태가 된다. -> 공격자가 TCP 흐름제어를 이용해서 요청에 대한 응답을 느리게 읽게 한다고 해서 Slow HTTP Read Dos 라고 표현함 -> 웹서버에서 Zero Window Packet을 수신하게 되면 클라이언트의 수신버퍼에 여유 공간이 없다고 판단하여 연결을 유지하면서 응답 데이터 전송을 대기함

* 해시 도스 공격 : 웹서버는 클라이언트로부터 전달받은 HTTP메시지의 매개정보 관리를 위해 해시테이블을 사용함 : 조작된 매개정보를 포함(조작된 파라미터)한 다량의 메세지는 해시테이블 검색을 위한 인덱스로 사용되는 해시값에 충돌을 발생시켜 정확한 값을 찾기 위해 모든 해시테이블을 검사하게 되는데 이때 웹서버의 CPU자원을 소진하게 되어 정상적인 서비스를 방해한다 -> 조작된 많은 수의 파라미터를 POST 방식으로 웹서버로 전달, 웹서버는 다수의 해시 충돌이 발생하게 되고 결과적으로 정상적인 파라미터 조회 시 많은 CPU 자원을 소모함

* 헐크도스 : GET Flooding 공격 유형으로 동일 URL을 지속적으로 요청시 차단될 수 있기 때문에 이를 우회하기 위해 URL을 지속적으로 변경하면서 공격하는 방식 -> 임계치(Threshold) 기반의 디도스 대응 장비를 우회할 수 있음

* Slowloris -> Slow HTTP Header Dos / RUDY -> Slow HTTP Post Dos 에 대한 공격 대으액
- 동시 연결에 대한 임계치 설정을 통한 차단 -> Threshold / iptables 방화벽 이용
- 연결 타임아웃 설정을 통한 차단 (완벽한 대응 방법은 아님)
- 읽기 타임아웃 설정을 통한 차단

* DRDos (Distributed Reflection Dos) : 공격자는 출발지 IP를 공격 대상 IP로 위조하여 다수의 반사서버로 요청정보를 전송, 공격대상은 반사서버로부터 다수의 응답을 받아 서비스 거부 상태가 되는 공격 유형 -> IP Spoofing, 반사서버, Dos

-> DRDos 공격 유형 : TCP연결설정과정의 취약점을 이용하여 위조된 출발지 주소의 SYN패킷을 반사서버로 전달하여 SYN+ACK응답패킷이 공격 대상으로 향하는 방법(SYN+ACK에 대한 ACK가 없을 경우 TCP 동작구조상 재전송을 다수 수행하므로 증폭이 발생함), ICMP 프로토콜의 Echo Request 와 Echo Reply를 이용하여 위조된 주소의 Echo Request를 반사서보로 전달하여 Echo Reply가 공격대상으로 향하도록 하는 방법, UDP 프로토콜 서비스를 제공하는 서버를 반사서버로 이용하여 그 응답이 공격대상으로 향하게 하는 방법

-> UDP 프로토콜을 사용하는 DNS, NTP, SNMP, CHARGEN 등의 서비스를 이용한 DRDos 공격은 크게 반사와 증폭 공격 형태로 나타남. 공격자는 출발지 IP를 공격대상 IP로 위조하여 취약한 서비스를 사용하는 서버에 대규모의 메시지를 보내고 서버는 요청에 대한 응답메시지를 공격대상 IP에 반사시도를 한다. 이때 반사된 응답메시지는 대량의 트래픽으로 증폭되어 공격대상에게 전달된다. -> 반사, 증폭 -> 증폭을 위해 DNS는 ANY,TXT등의 질의타입을 요청하여 대량의 응답 트래픽을 유발시킴, NTP서버에 최근 접속한 클라이언트 목록(monlist)을 요청하여 공격대상에게 대량의 응답 트래픽을 유발시킴, SNMP Agent에 MIB와 같은 정보를 대량으로 요청하여 공격대상에게 대량의 응답 트래픽을 유발시킴, CHARGEN 서버에 접속하여 공격대상에게 대량의 문자열 응답 트래픽을 유발시킴

* DRDoS 공격과 일반적인 Dos 공격과의 차이점 : DRDos 공격은 일반적인 Dos 공격에서 더 발전된 공격 형태로 봇넷 기기들이 직접 공격을 수행하는 것이 아니라 증폭 및 반사공격에 활용되는 서비스를 제공하는 서버를 공격 기기로 이용한다. IP 스푸핑 + 다수의 반사서버 경유로 인해 공격 근원지를 파악하는 것이 어렵다. 또한 요청 대비 응답이 크기 때문에 공격 트래픽 효율이 증가한다

-> 대응 방안 : IP주소가 위조된 패킷이 인터넷망에 유입되지 않도록 인터넷서비스제공자(ISP, 통신사)가 직접 차단한다. Ingress 패킷 필터링 (외부에서 내부 네트워크로 들어오는 패킷)에 대해 외부에 존재할 수 없는 IP를 필터링, Egress 패킷 필터링 (라우터를 이용하여 내부에서 외부 네트워크로 나가는 패킷에 대해 출발지 IP를 체크하여 내부에서 관리하고 있는 IP주소가 아니라면 위조된 주소로 판단하여 필터링), Unicast RPF 기법(라우터로 유입된 패킷의 출발지 IP에 대해

라우팅 테이블을 이용하여 유입된 인터페이스로 다시 전송되는지 여부를 체크하여 유입된 인터페이스로 다시 전송되지 않는다면 위조된 주소로 판단하여 필터링함), ICMP 프로토콜이 필요하지 않는 경우라면 반사서버로 악용되지 않도록 해당 프로토콜을 차단한다, DNS 서버가 악용되지 않도록 지정된 주소만 DNS 쿼리가 가능하도록 제한하거나 동일 출발지 IP에 대해 단위시간당 요청개수제한을 설정한다

* 무선랜 : 국제표준기구인 IEEE 에서 802.11 계열 표준으로 규정하고 있으며 무선랜 관련 장비들은 이 표준을 준수하고 있음 . Wifi와 혼용되어 사용. 기존 유선랜에 무선 AP를 연결한 후 클라이언트에 무선 랜카드를 장착하여 접속하는 형태로 구성되어 있음

-> 상용무선랜(USIM, MAC, ID/Password를 이용함. 이동통신사가 고객 서비스용으로 구축한 무선랜 환경)/공중무선랜(공공기관,호텔,카페등과 같은 서비스 업종에서 불특정 다수의 고객 편의를 우해 제공하는 무선랜 환경, 보안에 취약함)/사설무선랜(일반 사용자가 무선 공유기를 통해 구축한 무선랜 환경)/기업무선랜(기업이 내부 업무용으로 구축한 무선랜 환경)으로 나뉨

* 무선랜의 보안 취약점 - 물리적인 취약점 :무선AP의 외부 노출로 인해 발생하는 비인가자로인한 장비의 파손, 리셋을 통한 설정 초기화 / 무선 단말기의 분실 위험 및 정보 유출

* 무선랜의 보안 취약점 - 기술적인 취약점 : 암호화하지 않은 통신데이터에 대한 도청(무선랜은 공기를 전송매체로 하여 브로드캐스트 하는 특성을 가지므로 발생), 무선전파 전송장비에 대한 서비스거부공격 또는 주파수 대역에 방해전파, 비인증AP를 통한 전송 데이터 수집 (공격자가 불법적으로 무선 AP를 설치함)

* 무선랜의 보안 취약점 - 관리적인 취약점 : 무선 AP 장비에 대한 관리 미흡, 사용자의 보안 의식 부족, 전파 출력 관리 부족 (전파 출력 조정을 하지않으면 기관 외부로 무선랜 전파가 유출됨)

* SSID : Service Set Identifier -> 무선랜을 구분하기 위한 32byte 이름으로 서로 다른 무선랜을 식별하기 위한 용도 (wifi 를 활성화했을 때 나오는 무선랜 목록)
* BSS : Basic Service Set -> 무선랜의 가장 기본적인 망 구성단위로 특정 무선 AP(흔히말하는 공유기)와 AP에 연결된 스테이션(무선장비, 태블릿,노트북,스마트폰 등)들이 결합된 논리적인 망을 의미함
* BSSID : Basic Service Set identifier -> BSS를 식별하기위한 ID로 일반적으로 무선AP의 48bit MAC주소를 사용함
* ESS : Extended Service Set -> 무선 AP를 모두 엮는 논리적인 하나의 커다란 집합을 의미함
* ESSID : Extended Service Set Identifier -> 복수의 무선AP를 설치한 무선랜 환경에서 사용가능하도록 SSID를 확장한 무선랜 이름
* DS : Distribution System -> 무선AP가 연결된 유선 네트워크를 의미함 (무선 AP 이후에 반드시 유선을 거쳐서 통신함)
* 비콘(Beacon) 프레임/메시지 -> 무선AP가 자신이 관리하는 무선랜의 존재를 정기적으로 알리는 브로드캐스트 프레임/메시지로 스테이션으로 하여금 무선 네트워크를 찾도록 도와주는 역할을 수행한다

* 무선랜 보안 메커니즘 : 무선 패킷에 대한 기밀성과 무결성을 보장하기 위한 무선전송 데이터 암호기술과 통신상대방에 대한 신뢰성을 확인하기 위한 무선랜 접속 인증기술이 필요함 -> 무선전송데이터 암호기술, 무선랜접속인증기술

-> IEEE 802.11 에서는 별도의 기술X -> IEEE 802.11b 부터 WEP(Wired Equivalent Privacy) -> IEEE 802.11i 부터 WPA(WPA1), WPA2(Wifi protected Access) 보안규격 규정

* 무선랜은 인증 기술과 전송 데이터 암호화기술로 나뉨
-> 인증기술 : SSID숨김설정, MAC주소 인증,공유키 인증, IEEE 802.1x/EAP
-> 데이터 암호기술 : WEP, WPA, WPA2(Wifi protected Access)

* WEP(Wired Equivalent Privacy) : 유선랜과 동등한 수준의 보안성제공 목적으로 만들어진 초기 무선랜 보안기술로 IEEE 802.11b 표준에서부터 적용되었으며 데이터 암호화와 사용자 인증, 두 가지 기능을 모두 제공
-> 고정된 공유키와 무작위로 생성한 초기벡터(IV)를 조합 + RC4 알고리즘 기반의 데이터 암호화
-> 서로 같은 공유키를 갖는 사용자들을 정상적인 사용자로 인증하여 통신하는 공유키 인증방식
-> RC4 기반 알고리즘에 대한 취약점과 WEP 공유키가 쉽게 추출될 수 있는 취약점으로 인해 사용 비권장

* WEP 암호화 동작 방식 : 24bit 초기벡터 + 고정된 40bit 또는 104bit의 WEP공유키를 조합하여 WEP암호키를 생성하여 RC4알고리즘을 기반으로 한 난수발생기에 입력하여 스트림 암호를 위한 키스트림을 생성 -> 평문의 무결성을 보장하기 위해 CRC-32 알고리즘을 이용하여 무결성 체크값을 생성한 후 평문과 조합함 -> 평문과 ICV를 합친 데이터와 키스트림을 XOR하여 암호문을 생성함 -> 생성된 암호문에 초기벡터와 802.11 표준에서 사용하는 헤더를 추가하여 최종적으로 전송하고자 하는 패킷을 구성 함

* WEP 복호화 동작 방식 : 송신자가 보낸 패킷에서 초기벡터를 추출하고 이를 자신이 갖고 있는 WEP 공유키와 조합하여 난수발생기를 통해 키스트림을 생성한다 -> 암호문을 키스트림과 XOR하여 평문과 ICV를 생성한다 -> 복호화된 평문의 무결성 체크를 위해 CRC-32 알고리즘을 이용하여 IVC'를 구한 후 복호화된 ICV와 비교하여 패킷 무결성 여부를 검사한다 -> 무결성 체크가 성공적으로 이루어지면 최종적으로 평문 데이터를 수신한다.

=> 문제점 : 통신과정에서 IV는 무작위로 생성되지만 24bit의 짧은 길이를 사용하기 때문에 IV값이 재사용될 가능성이 높음, 불완전한 RC4 암호 알고리즘 사용으로 인해 암호키 노출 가능성이 높음, 짧은 길이의 암호키 사용으로 인한 공격 가능성이 높음, 암호키 노출로 인해 무선전송 데이터의 노출 위험성이 높음

* WEP 동작방식 : 무선 단말 이용자는 무선 AP에 연결요청 메시지를 전송함 -> 연결요청 메시지를 받은 무선AP는 임의의 문장을 생성하여 원본을 저장하고 연결요청 응답 메시지를 이용하여 사본을 전달함 -> 연결요청응답 메시지를 받은 사용자는 무선 AP가 보내온 임의의 문자를 자신이 가지고 있는 WEP 공유키를 이용하여 암호화 한 후 암호문을 무선 AP에 전송한다 -> 암호문을 전송받은 무선 AP는 자신의 공유키를 이용하여 복호화한 후 원본 문장과 비교하여 동일한 경우 정상적인 이용자로 인증한다

=> 문제점 : 단방향 인증 방식 제공으로 인한 취약성 존재 (사용자 입장에서는 악의적으로 설치된 불법 AP 인지 판단할 수 없음), 고정된 공유키 사용으로 인한 취약성 (무선랜을 사용하는 모든 장비가 동일한 WEP 공유키를 사용하기 때문에 외부로 유출될 경우 많은 문제가 발생한다, 위험 요소를 줄이기 위해 WEP 공유키를 주기적으로 변경해야 하지만 무선랜을 사용하는 장비가 많을 경우에는 각각 설정해야하는 어려움이 발생함)

* IEEE 802.11i 보안 표준 : 초기 무선랜 보안규격인 WEP의 취약성을 보완하기 위한 표준 -> 보다 강화된 인증 및 키교환 방식, 향상된 무선구간 암호 알고리즘 정의

-> WPA, WPA2로 분류함. WPA 버전은 암호 알고리즘으로 RC4-TKIP을 사용하고 WPA2 는 AES-CCMP를 사용함

cf. WPA2 는 사용되는 모드에 따라 WPA/WPA2-개인(PSK, 단말이 사전에 공유한 비밀키를 가지고 있으며 4-way handshake 절차에의해 확인함)과 WPA/WPA2-기업(802.1x/EAP 모드로 RADIUS 인증 서버를 이용하여 상호 인증을 수행하고 그 결과를 기반으로 AP접근을 허용함) 으로 구분

cf. RADIUS 프로토콜 : 네트워크를 통해 서버나 장비에 접속시 인증/인가, 계정관리를 중앙에서 처리할 목적으로 사용하는 프로토콜 중 하나

* WPA (WPA1) RC4-TKIP : 공유 비밀키를 동적으로 생성하여 무선 구간 패킷을 암호화 한다. WEP 방식의 하드웨어 교체없이 구현할 수 있도록 설계 됨, RC4를 사용하고 있지만 초기벡터를 48bit 로 늘리고 (24bit -> 48bit) 초기벡터의 순차 증가 규칙을 보완하며, WEP를 이용한 암호화 이전에 키 믹싱 함수를 이용한 별도의 키 생성 과정을 거쳐 각 패킷/프레임마다 별도의 암호키를 적용함, 무결성 검사를 위해 CRC-32 대신 MIC 를 각 패킷/프레임별로 적용한다.

=> IV 48bit, RC4, MIC
=> 문제점 : RC4 알고리즘 사용, 키 관리 방법 x, 무선 패킷 수집을 통한 키 크랙 공격에 대한 취약성, 소프트웨어 업그레이드를 이용함에 따른 암호화 복호화 시간지연 등의 성능상 문제

*WPA(WPA2) AES-CCMP : IEEE 802.11i 규격을 완전히 수용하는 표준으로 WPA와 구분하기 위해 WPA2로 정의한다. AES-CCMP를 통한 암호화 기능 향상, EAP를 통한 사용자 인증 강화, 패킷의 데이터 영역과 헤더의 무결성을 보장하고 패킷 번호를 이용하여 재전송 공격을 방지함, AES-CCMP 는 TKIP와 유사한 키 관리를 제공하지만 AES 기반의 128bit 대칭키를 사용하고 블록 암호 모드로 CCM 모드를 사용하는 차이점이 있음 -> 암호화 방식은 AES-CCMP / 인증방식은 EAP

cf. CCMP : Counter 모드 기반으로 CBC-MAC을 결합한 CCM(암호화와 메세지 인증 기능을 동시에 제공하는 블록 암호 모드, 암호화->CTR모드, 메시지 인증 -> CBC-MAC)

* WPA/WPA2-개인 인증방식 (PSK) : 인증 서버가 설치되지 않은 소규모 망에서 사용되는 방식으로 무선AP와 단말기가 자신과 동일한 공유키(PSK:Pre-Shared Key)를 가지고 있는지 802.1x에 규정된 EAPoL-Key 프레임을 활용하여 4-way handshake과정을 통해 확인하여 인증을 수행함 -> 무선 AP와 단말이 생성한 PTK가 동일하다 = PSK가 동일하다 = 정당한 사용자다

-> 무선 AP와 무선단말에 설정된 무선랜 접속 패스워드와 SSID 정보를 이용하여 256bit 사전 공유키를 각자 생성한다. PSK 생성방법 (PBKDF2 : Password-Based Key Derivation Function Version 2 -> 패스워드 기반 키 유도 함수, 입력값을 4096번 해시 반복을 수행한 후 256bit 키를 생성함)

Q. 사용자 패스워드를 기반으로 키 유도를 하기 위한 대표적인 함수는 ? PBKDF2 알고리즘

-> PSK는 무선랜 접속 패스워드와 SSID 정보를 알고 있는 사용자에 의해서만 생성되므로 이를 알고 있는 사용자를 정당한 사용자로 인증함, PSK는 이후 전송되는 파라미터와 PSK를 이용하여 512bit PTK를 생성한다.

-> 4단계 핸드쉐이크 과정을 통해 얻은 파라미터와 PSK를 이용하여 512bit PTK를 생성한다.
-> PTK는 이후 무선 AP와 단말 통신을 위해 세션 동안 사용되는 3개의 키로 파생된다 -> KCK부가적인 데이터 (EAPoL-Key Confirmation Key): 송수신메시지의 무결성, 송신처 인증을 위한 MIC용 키, KEK(EAPoL-Key Encryption Key): 부가적인 데이터 암호화/복호화용 키 , TK(Temporal Key): 송수신 데이터 암호화/복호화용 키

-> MIC는 PTK로 부터 파생된 KCK와 주고받은 파라미터를 HMAC 알고리즘(HMAC-MD5 또는 HMAC-SHA1)을 이용하여 생성함

=> 문제점 : WPA-PSK를 이용하여 무선 네트워크를 구성할 때 접속/인증 패스워드를 짧게 설정하거나 추측하기 쉬운 값으로 설정할 경우 사전 공격을 통해 손쉽게 패스워드를 크랙할 수 있는 취약점이 있음 (4-way handshaking 과정에서 PTK를 생성할 때 사용되는 파라미터 중 패스워드를 기반으로 생성한 PSK를 제외하고 모두 네트워크상에 노출 됨)

cf. 패스워드 사전 공격 절차 : 4-way handshaking 절차를 통해 스니핑 -> PSK를 추측하여 생성 -> PTK 생성 -> MIC 값 생성

* WPA-기업 인증 방식 (IEEE 802.1x/EAP) : WEP의 인증 상의 문제점을 해결하기 위해 802.1x 표준에서 EAP 인증기능을 제공하고 있음. (EAP : Extensible Authentication Protocol) -> 사용자 인증 방법으로 사용됨. RFC 2284 에 공식 명세 발표, RADIUS 사용

cf. EAP : 어떤 링크에도 접속이 가능한 단순한 캡슐화 개념의 프로토콜로 EAP 자체는 실제 인증 프로토콜이 아니지만 다양한 종류의 인증 방법을 전송하는 역할 -> EAP-MD5, EAP-TLS, EAL-TTLS, PEAP 등의 다양한 인증 방법을 지원함

* 무선랜 접속 인증 기술
- SSID 설정을 통한 접속 제한 -> 무선랜 관리자가 무선 AP의 SSID를 브로드캐스트하지 않도록 설정함
- MAC 주소 인증 -> 무선랜 접속을 허용할 단말의 MAC 주소를 무선 AP에 사전 등록하여 등록된 단말에 대해서만 접속을 허용해주는 인증방식 (공격자가 단말의 MAC 주소로 위조하면 쉽게 무력화 가능, 대규모의 네트워크에서 MAC 주소를 관리하기 위한 업무 부담이 큼)

cf. aircrack-ng : 무선랜에 대한 패킷 모니터링, 크래킹, 분석 도구 등이 포함 됨
cf. iwconifg : ifconfig와 유사한 명령으로 무선랜 인터페이스 정보를 확인하거나 환경 설정을 위해 사용되는 명령어

* 무선랜 인터페이스 모니터 모드 : 유선랜 인터페이스의 무차별모드(Promiscuous Mode)와 동일하게 해당 인터페이스로 전송되지 않는 주변의 모든 무선 패킷을 수신할 수 있는 모드, 무선랜 인터페이스의 기본 동작 모드는 관리 모드로 자신에게 전송되는 무선 패킷만을 수신하도록 동작함

* 무선랜 보안대책
- 기업 네트워크에서의 무선랜 보안 -> WPA2-기업의 RADIUS 서버를 활용한 EAP기반 인증을 하도록 권고함 , 전송 데이터 암호화는 안전성이 검증된 WPA2 보안규격의 AES-CCMP 방식을 권고함
- 개인 및 SOHO 사업자의 무선랜 보안 -> PSK 인증방식 설정 + 패스워드 크랙에 대해 충분히 안전한 비밀 번호 설정, 전송 데이터 암호화는 WPA2 보안규격의 AES-CCMP 방식 권장 / 무선랜사업자에서 제공하는 인증서버를 통한 단말 인증기능을 사용
- 무선AP 물리적/관리적 보안 : SSID변경(최초값에서 변경) 및 브로드캐스트 금지, 무선랜의 default 비밀번호 변경, 무선AP의 물리적 접근 제한

* 가설사성망(VPN:Virtual Private Network) : 인터넷과 같은 공중망을 이용하여 사설망이 요구하는 서비스를 제공할 수 있도록 구축한망, 공중망 내에서 마치 단일 회사만 사용하는 전용선 처럼 사용하는 기술
-> 터널링 프로토콜 + 보안 과정을 통해 내부 기밀을 유지하여 보안성이 우수, 라우터 체계의 비공개와 데이터 암호화, 사용자 인증, 사용자 액세스 권한 및 제한의 기능을 제공함

cf. 터널링 : 송신자와 수신자 사이의 전송로에 외부로부터의 침입을 막기 위해 일종의 파이프를 구성하는 것으로 파이프는 터널링을 지원하는 프로토콜을 사용하여 구현하고 있으며 사설망과 같은 보안 기능을 지원함, 터널링 되는 데이터를 페이로드라고 표현함 (터널링 구간에서 터널링 프로토콜을 통해 페이로드는 캡슐화 되어 전송된다.)

* VPN 프로토콜 종류
- PPTP(Point to Tunnel Protocol) : PPP의 Pakcet을 IP Packet으로 캡슐화하여 IP네트워크에서 전송하기 위한 터널링 기법. 하나의 터널에 하나의 연결만을 지원하므로 일대일 통신만 가능함
- L2F(Layer 2 Forwarding) : 시스코사에서 제안한 프로토콜, 하나의 터널에 여러 개의 연결을 지원하여 다자간 통신을 가능하게 함, 원격지의 ISP장비에서 접근 서버 측의 터널 서버로 L2F 터널을 생성시키며 이 가상 터널은 Direct-dial PPP/RAS 세션을 생성함, home site에서 주소를 할당하며 home site의 게이트웨이에서 사용자를 인증함, PPP를 사용하며 인증으로 RADIUS, TACACS+ 사용
- L2TP(Layer 2 Tunneling Protocol) : L2F에 기반을 두고 PPTP와의 호환성을 고려하여 만들어진 터널링 프로토콜, WAN 기술 지원 -> X.24, ATM, FrameRelay / IP, IPX, AppleTalk 프로토콜에 대해 지원
- IPSec(IP Security) : 3 계층 터널링 프토콜, IETF에 의해 제안되어 VPN 구현에 가장 많이 사용함, TCP/IP통신을 보다 안전하게 유지하기 위한 IP 데이터그램의 인증, 무결성과 기밀성 등을 제공함, 상위계층
프로그램의 변경이 필요하지 않음 -> IP 계층에서 직접 서비스, 암호화된 패킷은 보통의 IP패킷과 동일한 형태를 가짐

=> 2계층 VPN 프로토콜 : PPTP, L2F, L2TP
=> 3계층 VPN 프로토콜 : IPSec (가장 대표적임)

* IPSec : IETF 에서 IP 보안을 위하여 개방형 구조로 설계한 표준으로 IP 계층 보안에 대해 안정적이고 표준화된 기초를 제공함. 네트워크 계층에서 제공. IPv6에서 IPSec을 기본적으로 포함하고 있음

- 기밀성 (Confidentiality) : 메세지가 제3자에 의해 도청되어도 그 내용을 알 수 없음 / AH 프로토콜은 암호화를 지원하지 않으며 ESP프로토콜만 암호화를 지원함 , 대칭 암호화를 통한 기밀성 제공
- 비연결형 무결성 (Connectionless Integrity) : 메세지가 위변조 되지 않았음을 보장, MAC을 통해 각 IP패킷별로 무결성을 보장함
- 데이터원천 인증/송신처 인증 (Data Origin Authentication) : 수신한 메시지가 올바른 송신처로부터 온 것임을 보장함, MAC를 통해 IP패킷이 올바른 송신처로부터 온 것임을 보장함
- 재전송 공격 방지 (Protection Against Replays) : IP 패킷별로 순서번호를 전송하므로 재전송 공격을 방지함 (수신측에서 보안연관 Security Assocation 에서 순서번호를 유지하고 이를 검증함
- 접근 제어 (Access Control) : Security Policy, SP를 통해 송수신 IP 패킷에 대한 접근 제어 -> (IP 패킷의 허용 -ByPass, 폐기 - Discard, 보호 - Protect)
- 제한된 트래픽 흐름의 기밀성 (Limited Traffic Flow Confidentiality) : 트래픽 흐름이란 해당 패킷이 어디에서 출발해서 어디를 목적지로 향해 가는지에 대한 정보를 의미한다. ESP/터널모드는 New IP헤더를 통해 터널/보안 게이트웨이 구간의 트래픽 흐름 정보는 노출되지만 원본 IP헤더는 암호화 되어 있기 때문에 터널/보안게이트웨이와 종단노드 구간의 트래픽 흐름의 기밀성은 보장 된다

* IPSec 전송모드 : IP 패킷의 페이로드를 보호하는 모드, IP패킷의 페이로드만 IPSec으로 캡슐화하고 IP헤더는 그대로 유지하므로 네트워크상 패킷 전송에 문제가 발생하지 않음, IP헤더를 보호하지 않기 때문에 트래픽 흐름이 분석될 수 있음 (IPSec으로 캡슐화/IP헤더는 그대로 유지) -> 종단노드 구간의 IP패킷 보호를 위해 사용함

* IPSec 터널모드 : IP패킷 전체를 보호, 전송구간 주소 정보를 담은 New IP헤더를 추가함 (IP 헤더까지 캡슐화되므로 네트워크상 패킷 전송이 불가능해지기 때문), 원본 IP헤더를 보호하기 때문에 최초 출발지 및 최종 목적지에 대한 트래픽 정보의 기밀성을 보장해줌. 새로운 IP헤더를 통해 보안/터널과 게이트웨이 구간 정보는 노출될 수 있기 때문에 제한적 트래픽 흐름의 기밀성을 보장해줌

-> 터널/게이트웨이간을 보호하거나 종단노드와 게이트웨이간을 보호해줌 (총 2가지인 것)
-> 터널/게이트웨이간 보호 : 물리적으로 떨어진 위치의 본,지점 사이에 다수의 사용자 호스트와 서버로 구성된 VPN 환경
-> 종단노드 - 터널/게이트웨이 구간 보호 : 외부 사용자 호스트와 본/지점 사이의 VPN 환경구성

* IPSec 세부 프로토콜 AH : 메시지 인증코드를 이용하여 무결성에 대한인증과 송신처 인증을 제공, 기밀성은 제공하지 않음 -> 암호화제공 X, 인증데이터계산시 IP헤더의 변경가능한 필드(TTL, Header Checksum, NAT 환경에서의 source IP) 를 제외한 IP패킷 전체를 대상으로 함

cf. 구형 IPSec 를 사용하는 경우 NAT 환경에서 인증 데이터/MAC값 오류로 인해 장애가 발생하는 경우가 있음 -> NAT 환경에서 source IP 가 변경되므로 이를 제외 하고 인증 데이터를 계산해야 하지만 제외하지 않아서 장애가 발생함 . ESP 프로토콜을 사용하면 정상통신 가능 (ESP 는 데이터계산에 IP헤더가 포함되지 않기 때문)

* AH 주요 헤더필드 : SPI (현재 연결에 대한 보안연관 식별자), 순서번호(재전송 공격을 방지하기위한 필드, 일련번호가 항상 1씩 증가), 인증 데이터 Integrity Check Value (IP 헤더의 변경 가능한 필드를 제외한 IP 패킷 전체에 대한 MAC 값)

* AH 프로토콜 동작 모드 : 전송모드 -> IP 헤더의 전송 중 변경 가능한 필드를 제외한 IP 패킷 전체를 인증 / 터널 모드 -> New IP 헤더의 전송 중 변경 가능한 필드를 제외한 New IP 패킷 전체를 인증함

* IPSec 세부 프로토콜 ESP : 메시지 인증 코드와 암호화를 이용하여 인증, 송신처 인증, 기밀성을 제공 -> 인증과 암호화를 선택적으로 적용할 수 있음. IP헤더를 인증하지 않음 (AH 는 변경가능한 IP헤더 필드를 제외한 IP패킷 전체를 인증함)

* ESP 주요 헤더 필드 : SPI, 일련번호, ESP 트레일러 필드(블록 암호를 위한 패딩 정보, 전송하는 페이로드의 프로토콜 타입 정보), ESP Auth 필드 (인증 데이터 정보 저장)

* ESP 프로토콜 동작 모드 : 전송모드 -> IP 페이로드와 ESP 트레일러를 암호화하고 암호화된 데이터와 ESP 헤더를 인증함 / 터널모드 -> 원본 IP 패킷 전체와 ESP 트레일러를 암호화하고 암호화된 데이터와 ESP 헤더를 인증함

* SA (Security Association) 과 SP (Security Policy)
- SA : 보안연관, 둘 사이의 논리적인 연결 상태를 유지하는 동안 적용할 보안 설정 정보를 보안 연관이라고 함 , 보안 연관은 단방향성/일방향성을 갖기 때문에 대상 호스트와 송수신을 모두 하려면 2개의 보안연관이 필요하다, SAD-> 여러 보안연관을 저장해놓은 데이터베이스를 보안연관 데이터베이스라고 한다, SPI, Sequence Number Counter, Anti-Reply Window, AH/ESP, Lifetime, Mode, Path MTU 가 포함 됨
- SP : 보안 정책, 패킷을 송신하거나 수신했을 때 적용할 보안의 종류를 정의하는 것 , Bypass(허용), Discard(폐기), Protect(IPSec 적용) 등이 있음, SP를 저장한 SPD 존재 ->보안 정책들을 저장해 놓은 데이터 베이스를 보안 정책 데이터 베이스라고 표현함)

* IPSec 패킷 송신 절차 : 전송할 패킷에 대해서 보안 정책 데이터베이스를 검색함 - SPD에 일치하는 엔트리가 없으면 패킷을 삭제함 -> 일치하는 엔트리가 있으면 첫 번째 엔트리의 정책에 따라 처리함 -> discard(폐기), bypass(송신), protect(보안 연관 데이터베이스 검색), 보안 연관 데이터베이스에 일치하는 엔트리가 있으면 IPSec 처리를 수행한 후 전송하고 일치하는 엔트리가 없으면 인터넷 키교환 과정(IKE)을 수행하여 SA를 생성하는 과정을 수행한다

*IPSec 패킷 수신 절차 : IP 프로토콜의 protocol 필드를 조사하여 보호되지 않은 IP 패킷인지 IPSec 패킷인지 검사함 -> 보호되지 않은 IP 패킷이라면 보안 정책 데이터베이스를 검색하여 첫 번째 일치하는 엔트리가 허용 정책이면 상위 계층으로 전달하고, 폐기 또는 보호라면 패킷을 삭제한다 -> IPSec 패킷이라면 보안 연관 데이터베이스를 검색하여 일치하는 엔트리가 없으면 패킷을 삭제하고 일치하는 엔트리가 있으면 IPSec 처리를 수행한 후 상위 계층으로 전달한다.

* IKE - Internet Key Exchange (인터넷 키교환 프로토콜) : 보안 관련 설정을 생성, 협상 및 관리하는 프로토콜로 500/udp 포트를 사용함. IPSec에서 양 당사자 간의 논리적인 연결정보 및 보안설정을 보안연관(SA)이라고 함.

-> IKE 1단계 : 2단계에서 사용할 메시지들을 어떻게 보호할 것인지 협상함, IKE용 마스터키 생성, 이 단계를 통해 생성된 보안연관을 IKE SA 라고 하고 양방향성을 가짐 -> Main Mode(세션아이디를 암호화 하므로 보안성이 높음), Aggressive Mode (세션아이디를 암호화 하지 않으므로 보안성이 낮음)

-> IKE 2단계 : 실질적인 데이터를 어떤 방식으로 보호할지 협상하는 단계, IPSec SA 가 생성됨, 1단계를 통해 생성된 키를 이용하여 메시지가 보호되며 Quick Mode를 통해 구현함 . SA 는 단방향성을 가지므로 수신용 SA와 송신용 SA가 각각 생성 됨

* 전송 계층 보안 - SSL/TLS : 웹 브라우저를 위한 보안 프로토콜로 처음 제안되어 1996년 SSL 3.0 버전까지 발표, 클라이언트/서버 환경에서 TCP 기반의 Application에 대한 종단 간 보안 서비스를 제공하기 위해 만들어진 전송계층 보안 프로토콜임 -> 각 애플리케이션 프로토콜이 SSL을 이용할 경우 이를 구분하기 위해 고유한 well-known 포트를 할당함

- 기밀성(Confidentiality) : 대칭암호를 이용한 송수신 메시지 암호화를 통해 기밀성을 제공함

- 무결성 : 메시지 인증코드를 통해 송수신 메시지의 위/변조 여부를 확인할 수 있는 무결성을 제공
- 인증 : 공개키 인증서를 이용한 서버/클라이언트 간 상호 인증을 수행함

-> Application Layer (HTTP) -> SSL/TLS Layer -> Transport Layer (TCP)
-> SSL/TLS는 상위계층(HandShake, Change Cipher Spec, Alert, Application Data)/하위계층(Record)으로 구성된 크게 2계층으로 이루어진 프로토콜임

* SSL/TLS 세부 프로토콜의 기능 : Handshake 프로토콜 -> 종단 간에 보안 파라미터를 협상하기 위한 프로토콜, Change Cipher Spec 프로토콜 -> 종단 간에 협상된 보안 파라미터를 이후부터 적용/변경함을 알리기 위한 프로토콜, Alert 프로토콜 -> SSL/TLS 통신 과정에서 발생하는 오류를 통보하기 위한 프로토콜, Application Data 프로토콜 -> application 계층의 데이터를 전달하기 위한 프로토콜, Record 프로토콜 -> 적용/변경된 보안 파라미터를 이용하여 실제 암호화/복호화, 무결성보호, 압축/압축해제 등의 기능을 제공하는 프로토콜

* SSL/TLS 상태 유지 프로토콜 : 세션과 연결 기반의 상태 유지 프로토콜 -> 완전 협상을 통해 세션을 생성, 이 세션 정보를 공유하는 다수의 연결을 단축 협상을 통해 생성함 / 세션 상태 정보 -> 양 종단 간에 완전 협상을 통해 생성되는 상태 정보로 세션이 유지되는 동안에 지속적으로 다수의 연결에 의해 사용되는 보안 파라미터 정보가 관리 됨 (대칭 암호 알고리즘, HMAC용 해시 알고리즘) / SSL/TLS 연결 상태 정보 -> 실제 통신이 이루어지는 단위로 단축 협상을 통해 생성되며 세션 상태를 공유하면서 통신을 수행함, 대표적인 상태 정보로 암호키와 인증키가 있음

* SSL/TLS Handshake 프로토콜을 통한 완전 협상 과정
1) Client Hello : 클라이언트가 지원가능한 SSL/TLS 버전, 암호도구목록, 압축 방식등을 서버에 전달함 / 클라이언트가 생성하는 32 bit 난수값인 client random 전달, 서버 세션을 식별하기 위한 세션ID 생성 -> 처음 세션을 생성할 때인 완전협상에서는 빈값이고 단축협상시 세션ID를 담아서 전달함, 클라이언트에서 지원 가능한 암호도구목록(cipher suites)에 대한 정보를 담아서 전달
2) Server Hello : 사용할 SSL/TLS 버전, 암호도구, 압축 방식등을 클라이언트에게 전달, server random(32bit 난수), 세션 ID
3) Server Certificate 메시지 : 필요시 서버 인증서 목록을 클라이언트에 전달하는 메시지
4) Server Key Exchange 메시지 : 필요시 키 교환에 필요한 정보를 전달함
5) Certificate Request 메시지 : 필요시 클라이언트 인증을 위한 인증서를 요청
6) Server Hello Done : Server Hello 과정 종료를 알리는 메시지
7) Client Certificate : 클라이언트 인증서 목록을 전달하는 메시지 , Ceritifcate Request 에 대한 응답
8) Client Key Exchange : 키 교환에 필요한 사전 마스터 비밀을 생성하여 서버에 전달하는 메시지로 키 교환 알고리즘에 따라 사전 마스터 비밀(premaster secret)을 생성하는 방법이 다르다. -> RSA (난수값인 premaster secret 생성 후 수신한 서버 인증서의 공개키를 이용하여 암호화 전송)/ Diffie-Hellman (클라이언트 Diffie-Hellman 공개키를 생성하여 서버에 전달, 클라이언트와 서버는 각각 Diffie-Hellman 연산을 통해 공통의 premaster secret를 생성함)
9) Certificate Verify 메시지 : 피룡시 클라이언트가 보낸 인증서에 대한 개인키를 클라이언트가 가지고 있음을 증명하는 메시지 , Certificate Request 에 대한 응답
10) Change Cipher Spec : 협상한 암호 명세를 이후부터 적용/변경함을 알리는 메시지
11) Finished : 협상 완료를 서버에 알림
12) Change_Cipher_Spec : 협상한 암호 명세를 이후부터 적용/변경함을 알리는 메시지
13) Finished : 협상 완료를 클라이언트에 알리는 메시지

* SSL/TLS Handshake 프로토콜을 통한 단축 협상 과정
10) Client Hello : 사용할 session id와 client random을 전달하는 메시지
11) Server Hello : server random을 전달하는 메시지

* record 프로토콜 동작 방식 : 단편화 -> 압축 후 MAC 추가 -> 암호화 -> Record 헤더 추가

cf. record 프로토콜 : 협상된 알고리즘을 이용하여 메시지를 압축/압축해제, 무결성 검증, 암호화/복호화 하여 송수신하는 기능

* SSL/TLS와 완전 순방향 비밀성 (Perfect Forward Secrecy -> PFS) : 서버 개인키가 노출되어도 이전 트래픽 정보의 기밀성은 그대로 유지되는 암호학적 성질을 완전 순방향 비밀성, PFS 라고 한다. 클라이언트 서버 간에 키 교환에 사용되는 서버 개인키가 노출되어도 이전 트래픽의 세션키/비밀키 기밀성은 그대로 유지되어 통신 내용을 알 수 없는 암호학적 성질을 말함

-> 키 교환시마다 클라이언트/서버가 새로운 Diffie-Hellman 개인키를 생성하는 임시 디피-헬만 키 교환을 통해 클라이언트/서버간 공통의 비밀값을 생성하고 서버 개인키는 서버 Diffie-Hellman 파라미터를 인증하는 목적으로만 사용함으로써 서버 개인키가 노출되어도 통신 내용을 알 수 없는 완전 순방향 비밀성을 지원한다. 단, RSA 에 비해 처리 속도가 느리므로 성능상의 이유로 DHE(Ephemeral Diffie-Hellman), ECDHE(Elliptic Curve DHE) cipher suite를 비활성화 하는 경우가 있다.

* 라우터 자체 보안
- User EXEC 모드 : 한정된 명령어만 사용할 수 있으며 주로 라우터의 간단한 상태 등을 조회할 수 있다. 프롬프트는 Router>
- Privileged EXEC 모드 : 재부팅이나 라우팅 등 라우터에서의 모든 명령어에 대해 수행이 가능하며 프롬프트는 Router#
- Global Configuration : Privileged EXEC 모드에서 라우터 전반적인 설정을 변경하고자 할 때의 모드로 Router(conifg)# 와 같이 보임
- Other Configuration : 좀 더 복잡하고 세부적인 설정을 하는 메뉴, Router(config-mode)$, exit 나 ctrl +z 로 종료할 수 있음

* 라우터 명령어 - enable password 패스워드 : tpye 0 의 평문으로 저장, 평문으로 저장된 암호는service password-encrpytion 명령을 실행하면 암호화를 수행하는데 type 7 방식(역함수가 존재하여 원래의 평문 암호를 알 수 있는 방식)으로 암호화 함

* 라우터 명령어 - enable secret 패스워드 : type 5(일방향 함수로 암호화/MD5)의 암호문으로 저장되어 원래의 평문 암호를 알 수 없다. enable password 보다 우선순위가 높다.

* 라우터와 접근 제어 : 라우터에서는 access-list 라는 것을 이용하여 특정 패킷에 대한 접근 제어를 설정할 수 있다.
- standard access-list : 패킷의 소스 IP 만으로 패킷을 허용하거나 차단함. acl number 로 1~99 까지 사용함, ip 대역을 지정할 경우에는 host 를 명시하지 않고 wildcard 마스크를 명시함
- extended access-list: 패킷의 소스 IP 뿐만 아니라 목적지 IP, 포트, 프로토콜 등을 이용하여 차단할 수 있어 좀 더 확장된 기능을 이용 가능함, acl 100~199, ip 대역을 지정할 경우에는 host를 명시하지 않고 wildcard 마스크를 명시한다

cf. wildmask 는 subnet mask 비트를 반전시킨것과 동일함

* filtering 유형
- Ingress Filtering : standard 또는 extended access-list를 활용하여 라우터 내부로 유입되는 패킷의 source ip 나 목적지 port 등을 체크하여 허용하거나 거부하도록 필터링 함
- Egress Filtering : 라우터 내부에서 외부로 나가는 패킷의 source ip나 목적지 port 등을 체크하여 필터링 함
- Blackhole Filtering (Null routing) : 특정 ip 또는 ip 대역에 대하여 비정상적인 시도가 감지 되었을 경우 가상의 쓰레기 인터페이스로 보내도록 함으로써 패킷 통신이 되지 않도록 하는 방법
- Unicast RPF (Reverse-Path Forwarding) Filtering : access-list 나 blackhole 필터링을 이용하여 일일이 ip 또는 ip 대역을 지정하지 않고도 비정상 트래픽을 효율적으로 필터링 하는 기법, 인터페이스를 통해 들어오는 패킷 소스 ip 에 대해 라우팅 테이블을 확인하여 들어온 인터페이스로 다시 나가는지 확인하는 원리

* 라우터를 통한 네트워크 보안 : 콘솔, AUX, VTY 포트 패스워드 보안 -> 콘솔 포트는 케이블을 이용하여 직접 터미널에 연결하여 라우터를 조작할 수 있도록 하며 장애 처리시 많이 사용함 (패스워드를 설정하지 않으면 바로 접근 가능하므로 여러사람이 콘솔을 사용할 수 있는 경우 콘솔 패스워드를 반드시 설정 해야 함) , VTY 포트는 원격지에서 텔넷을 통하여 접속 시 사용되는 패스워드를 설정함, AUX는 잘 사용하지 않음

-> 텔넷 접근 제한 : 기본적으로 VTY 포트는 외부로부터 연결 시도를 모두 받아들이므로 무한대의 공격 시도를 하여 라우터를 공격할 수 있다. 따라서 라우터로 들어오는 패킷의 IP주소를 차단하여 허가된 IP를 가진 사용자에게만 연결 시도를 허용하는 것이 안전 함, 또한 SSH 는 암호화된 통신을 제공하지만 텔넷은 암호화 하지 않으므로 가급적이면 SSH 로 통신하는 것을 권고함

-> SNMP 설정 : TPC/IP 네트워크를 모니터링하고 관리하기에 아주 효율적인 프로토콜. 대부분의 네트워크 장비들이 기본적으로 SNMP 서비스들을 포함하고 있어서 원격의 네트워크에 관련된 정보들을 수집할 수 있음. 기본적으로 SNMP 읽기 권한은 기본적으로 설정되어 있어 악용되는 경우가 많으므로 community string 값을 public(기본값) 에서 변경해 줘야함, 또한 access-list를 이용하여 접근 통제를 하고 SNMP 정보 수신이 필요한 장비를 명시하여 허용하고 나머지는 차단하도록 한다. SNMP 서비스를 사용하지 않는다면 서비스를 제거하는 것이 좋음, SNMP version 1,2 는 평문으로 정보를 전송하는 데 반해 SNMP version 3 은 암호화가 지원되므로 SNMP version 3 의 지원 여부를 확인하여 사용하는 것이 좋음

* 라우터에서 불필요한 서비스 제거 : 라우터는 네트워크 관리자의 편의를 위해 여러가지 기능을 제공하지만 이게 악용될 수 있음 -> 불필요한 서비스는 보안 위협 요소가 될 수 있으므로 모두 차단하자

- ICMP MTU Discovery : ICMP 패킷을 차단하더라도 MTU discovery 를 제공하는 패킷은 허용해야 네트워크가 제대로 동작할 수 있음 -> ICMP tpye3 , 4가 MTU discovery 를 담당함
- ICMP Redirects : 악의적인 공격자들이 ICMP Redirect를 전송하여 네트워크를 지나는 패킷의 방향을 바꿔서 정보 수집이 가능하므로 차단하는 것을 권장함.
- ICMP Directed Broadcasts : 라우터에서 directed broadcast를 허용하면 외부에서 브로드캐스트 주소로 특정 패킷을 전송하여 해당 네트워크의 모든 호스트에 전달할 수 있다. 공격자가 도스나 디도스 공격에 악용할 수 있으므로 차단을 권장함
- ICMP Mask Reply : 라우터가 해당하는 네트워크의 서브넷 마스크를 전송하도록 함 . 공격자는 이 기능을 통해 네트워크의 구성을 알아낼 수 있으므로 이 기능은 차단하는 것이 권장 됨
- ICMP Unreachable : 공격자에 의해 시도되는 많은 스캐닝 기법들은 ICMP Unreachable을 사용하여 라우터 혹은 호스트의 특정 포트가 열려 있는지 판단하므로 차단하는게 좋음
- ICMP Timestamp and Information Requests : 네트워크 관리자가 많이 사용하는 정보는 아니지만 공격자로 하여금 네트워크 현황을 알 수 있게 하는 취약점 이므로 두 개의 서비스를 모두 차단하는 것이 권장 됨

-> Source Route 사용 중지 : 패킷이 전송되는 경로를 각각의 시스템이나 네트워크에 설정된 라우팅 경로를 통하지 않고 패킷의 발송자가 설정할 수 있는 기능. 악용될 소지가 있으므로사용 중지 권장

-> Small Service : 시스코 라우터에 사용되고 있는 IOS 버전에 따라서 TCP, UDP Small Services 가 자동으로 설정되어 실행 됨. echo/discard/daytime 등 20번 이하 포트를 사용하고 있으며 네트워킹에 특별히 중요한 역할을 담당하지는 않기 때문에 모두 차단하는 것이 권장 됨

-> Finger 서비스 : 원격의 사용자로 하여금 어떤 사용자가 라우터에 접속해 있는지를 알려주는 역할을 함. 라우터에 로그인할 수 있는 사용자의 이름을 비롯한 중요한 정보를 제공하기에 공격자들이 많이 사용하는 서비스중의 하나이므로 차단을 권장함.

-> Http Service : 라우터에 해당 서비스가 설정되어 있으면 웹을 통해 라우터의 설정을 조회하거나 변경할 수 있으므로 사용 중지 권장

-> CDP 서비스 : LAN 구간에서 직접 연결된 시스코 장비들 사이에서 서로의 정보를 얻기 위해 사용되는 프로토콜 , 라우터에 연결된 장비들의 종류와 설정을 보여주기 때문에 전체 네트워크 구성을 파악할 때 많이 사용 함

-> proxy-arp 서비스 : 디폴트 라우터나 게이트웨이를 가지고 있지 않은 네트워크의 호스트들에게 arp 서비스를 제공하는 역할을 함. 이 경우 호스트가 목적지 IP 주소에 대한 MAC 주소를 요청하면 Proxy ARP가 설정된 라우터가 이에 응답하여 자신의 MAC 주소를 목적지 MAC 주소인 것처럼 전송한다. 공격자들은 패킷의 주소를 위조하여 Proxy ARP를 요청할 수 있으며 라우터가 이에 응답하는 것을 이용하여 라우터와 네트워크에 관련된 정보를 획득할 수 있으므로 차단을 권장함

-> 기타 불필요한 서비스 차단 : bootP, DNS, Network authloading of configuration files, PAD, IP Classless, 사용하지 않는 interface는 반드시 shutdown

* 라우터에서 입출력 IP 보안설정 : 외부에서 내부로 유입되는 IP주소가 내부의 IP주소라면 이는 공격자에게 악용된다고 보고 차단 필요, 외부 유입 IP 주소 중 예약된 IP주소가 있다면 차단하는 것을 권장, 내부에서 외부로 유출되는 IP주소가 위변조되어 출력되는 것을 차단, ACL을 이용하여 내부 네트워크 IP를 가진 패킷만 라우터로부터 전송되는 것을 허용하고 나머지 패킷들은 모두 차단하도록 한다.

cf. 예약된 IP 주소

- 127.0.0.0/8
- 10.0.0.0/8
- 172.16.0.0/12
- 192.168.0.0/16
- 224.0.0.0/4
- 240.0.0.0/5
- 255.255.255.255/32

* 라우터에서 주소 위변조 방지 : Unicat RPF 이용 (reverse path 가 존재하면 통과, 존재하지 않으면 위조 패킷으로 판단)

* 라우터에서 DDos 대응 방법 : BlackHole 보안 설정 -> 해당 목적지 IP를 망 내에서 통신할 수 없도록 차단함